

MỞ ĐẦU

1. Lí do chọn đề tài

Du lịch homestay tại Đồng bằng sông Cửu Long nói chung và Trà Vinh nói riêng đang tăng nhanh cùng làn sóng du lịch trải nghiệm và du lịch cộng đồng. Khác với khách sạn, homestay thường do hộ gia đình tự vận hành, quy mô từ vài phòng tới vài chục phòng, và không có bộ phận lễ tân trực suốt ngày đêm.

Thực tế vận hành của nhóm cơ sở lưu trú này bộc lộ ba vấn đề.

Thứ nhất, kênh đặt phòng phân mảnh. Chủ homestay nhận đặt phòng qua nhiều kênh tin nhắn khác nhau và đôi khi qua sàn trung gian. Mỗi kênh là một danh sách riêng trong trí nhớ hoặc trên một cuốn sổ. Không có nơi nào cho biết một ngày cụ thể còn bao nhiêu phòng ngoài việc tự nhớ lại.

Thứ hai, rủi ro đặt trùng phòng là rủi ro thường trực. Khi hai khách liên hệ gần như cùng lúc và chủ nhà trả lời còn phòng cho cả hai, sai sót chỉ lộ ra vào ngày nhận phòng, lúc không còn cách khắc phục nào ngoài việc từ chối một khách đã đi đường xa tới nơi. Đây không phải lỗi bất cẩn mà là hệ quả tất yếu của việc quản lý lịch phòng bằng trí nhớ con người.

Thứ ba, chi phí hoa hồng của sàn trung gian. Các sàn đặt phòng trực tuyến thu khoảng 15–20% giá trị mỗi đơn. Với homestay quy mô nhỏ, đó là phần lớn biên lợi nhuận. Nhưng rời sàn thì mất luôn kênh tiếp cận khách.

Một website đặt phòng riêng giải quyết cả ba vấn đề: gom mọi đơn về một nơi, để cơ sở dữ liệu chứ không phải trí nhớ con người bảo đảm không bán trùng phòng, và giữ lại toàn bộ doanh thu.

Về mặt học thuật, đề tài có giá trị riêng. Bài toán chống đặt trùng phòng là một bài toán tranh chấp dữ liệu kinh điển, không giải được đúng bằng cách kiểm tra thông thường ở tầng ứng dụng. Nó đòi hỏi hiểu biết về giao dịch cơ sở dữ liệu, mức cô lập và ràng buộc toàn vẹn ở tầng lưu trữ — những nội dung cốt lõi của ngành mà một đề tài quản lý thông thường không chạm tới.

2. Mục đích nghiên cứu

Xây dựng một website hoạt động được, có dữ liệu minh hoạ, giải quyết đúng bài toán giới thiệu và đặt phòng homestay, gồm ba khối: trang bán hàng cho khách, khu quản trị cho chủ homestay, và giao diện lập trình ứng dụng kết nối hai khối.

Tám mục đích cụ thể cùng tiêu chí nghiệm thu tương ứng:

#	Mục đích	Tiêu chí nghiệm thu
1	Khách tìm được phòng trống theo ngày và đặt phòng thành công	Đặt được đơn từ trang chủ tới khi có mã QR
2	Hệ thống không bao giờ bán trùng một phòng	Kiểm thử đa luồng: đúng một luồng thắng
3	Đặt cọc qua mã QR, webhook tự xác nhận	Đơn tự chuyển trạng thái khi tiền về đủ
4	Không có nhánh nào để tiền của khách biến mất im lặng	Mọi khoản không khớp vào hàng đợi đối soát
5	Quản trị viên quản lý được phòng, giá, số khách và ngày khả dụng	Đóng phòng theo khoảng ngày, hệ thống tự mở lại
6	Giao diện đạt chuẩn trang đặt phòng thương mại	Không còn lỗi vi phạm WCAG mức A và AA
7	Một lệnh là đủ để chạy toàn hệ thống kèm dữ liệu mẫu	Ba lệnh từ lúc sao chép mã nguồn tới lúc chạy
8	Tài liệu kỹ thuật đầy đủ	12 tài liệu kỹ thuật kèm mã nguồn

3. Đối tượng nghiên cứu

Đề tài nghiên cứu ba đối tượng:

1. **Quy trình nghiệp vụ** đặt phòng lưu trú ngắn ngày của cơ sở homestay quy mô nhỏ, từ lúc khách tìm phòng tới lúc trả phòng.
2. **Cơ chế bảo đảm toàn vẹn dữ liệu khi có tranh chấp** trong hệ quản trị cơ sở dữ liệu quan hệ PostgreSQL, cụ thể là kiểu dữ liệu khoảng, ràng buộc loại trừ và chỉ mục GiST.
3. **Kiến trúc ứng dụng web tách rời** giữa tầng giao diện và tầng máy chủ, giao tiếp qua giao diện lập trình ứng dụng theo kiểu REST.

4. Phạm vi nghiên cứu

Về nghiệp vụ: từ lúc khách tìm phòng tới lúc trả phòng, cộng với đối soát thanh toán và báo cáo doanh thu. Không bao gồm kế toán, thuế, nhân sự, kho.

Về kỹ thuật: Java 21 và Spring Boot 3.5.6 ở tầng máy chủ; Angular 21 và Tailwind CSS 4 ở tầng giao diện; PostgreSQL 16 làm cơ sở dữ liệu; Docker Compose để đóng gói.

Về dữ liệu: dữ liệu minh hoạ tự sinh, mô phỏng một homestay 15 phòng thuộc 4 loại phòng.

Ngoài phạm vi. Việc nêu rõ giới hạn là một phần của thiết kế:

Không thực hiện	Lý do
Kết nối cổng thanh toán thật	Đề tài không yêu cầu; hệ thống viết đúng luồng thật và đọc khoá từ biến môi trường
Hoàn tiền tự động	Hoàn tiền là quyết định kinh doanh; hệ thống đưa vào hàng đợi cho người xử lý
Ứng dụng di động	Website đã đáp ứng trên điện thoại
Đa ngôn ngữ và đa chi nhánh	Không thuộc lõi nghiệp vụ của một cơ sở đơn lẻ
Giao thức bảo mật HTTPS trong bản đóng gói	Cần tên miền và chứng chỉ thật; là giới hạn đã biết, trình bày ở mục 4.6

CHƯƠNG 1. TỔNG QUAN

1.1. Giới thiệu bài toán

1.1.1. Mô tả cơ sở

Homestay TVH là một cơ sở lưu trú đặt tại Trà Vinh, quy mô **15 phòng vật lý** thuộc **4 loại phòng**: Standard, Deluxe, Family và Bungalow. Mỗi loại phòng có giá cơ bản theo đêm, sức chứa người lớn và trẻ em riêng, bộ tiện nghi riêng và bộ ảnh riêng.

Nghiệp vụ cần tin học hoá gồm bốn nhóm:

Nhóm 1 — Giới thiệu. Trình bày loại phòng, tiện nghi, hình ảnh, tin tức và đánh giá của khách cũ, sao cho khách chưa từng biết tới homestay vẫn hình dung được họ sẽ nhận được gì.

Nhóm 2 — Đặt phòng. Khách chọn khoảng ngày và số khách, hệ thống trả về các loại phòng còn chỗ kèm chi phí dự kiến, khách gửi yêu cầu đặt phòng và đặt cọc.

Nhóm 3 — Quản lý vận hành. Chủ homestay theo dõi đơn theo trạng thái, xác nhận hoặc huỷ, đối soát tiền đã nhận, và quản lý danh mục phòng, giá, khuyến mãi, nội dung trang chủ.

Nhóm 4 — Báo cáo. Doanh thu theo tháng, tỉ lệ lấp đầy, tỉ lệ huỷ.

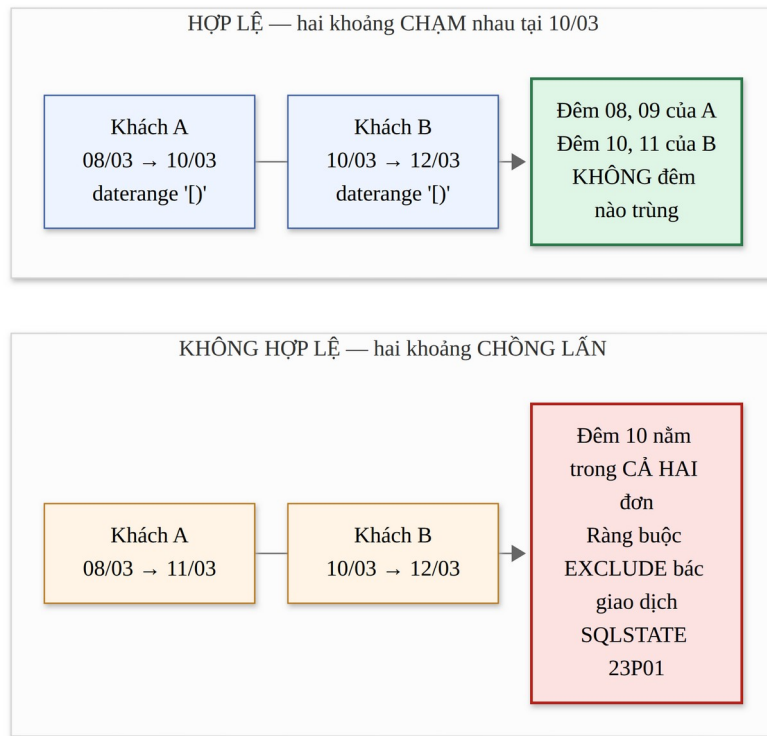
1.1.2. Bài toán cốt lõi: không được bán trùng một phòng

Đây là ràng buộc nghiệp vụ nghiêm ngặt nhất và là trục kỹ thuật của toàn đồ án. Phát biểu hình thức:

Với mọi phòng vật lý p , không tồn tại hai đơn đặt phòng còn hiệu lực cùng giữ p mà khoảng ngày ở của chúng giao nhau.

Điểm tinh tế nằm ở chữ "giao nhau". Nó phải hiểu theo **khoảng nửa mở**. Khách A trả phòng ngày 10/03 và khách B nhận phòng ngày 10/03 là hợp lệ — buổi sáng A trả, buổi chiều B nhận. Nếu cài đặt bằng phép so sánh ngày thông thường, chỉ cần lệch một dấu bằng là hoặc mất một đêm doanh thu mỗi phòng, hoặc bán trùng.

Hình 1.1 minh hoạ sự khác biệt giữa hai khoảng chạm nhau và hai khoảng chồng lấn thật sự.

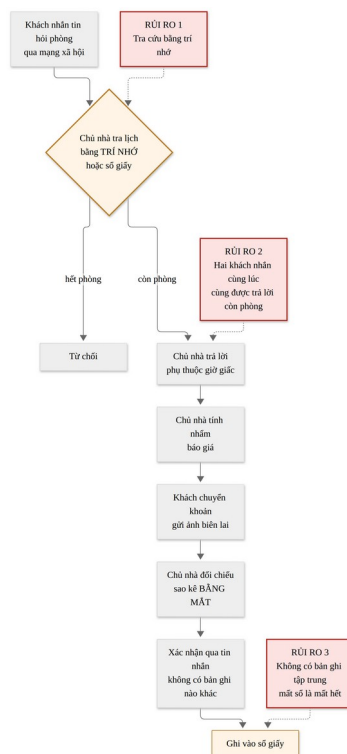


Hình 1.1 (Nguồn: tác giả)

1.2. Khảo sát hiện trạng

1.2.1. Quy trình thủ công hiện tại

Hình 1.2 mô tả quy trình đặt phòng thủ công đang được áp dụng phổ biến tại các cơ sở homestay quy mô nhỏ, cùng ba điểm rủi ro chính.



Hình 1.2 (Nguồn: tác giả)

Bảy bước của quy trình đều có nhược điểm. Khách xem ảnh trên trang mạng xã hội nên không biết giá và tình trạng phòng. Việc hỏi phòng trống phụ thuộc giờ giấc chủ nhà. **Bước tra lịch bằng trí nhớ là nguồn gốc của việc đặt trùng phòng.** Báo giá tính nhầm để nhầm khi khách ở nhiều đêm hoặc đặt nhiều phòng. Đối chiếu tiền cọc làm bằng mắt trên sao kê. Xác nhận không để lại bằng chứng nào ngoài đoạn hội thoại. Và toàn bộ dữ liệu nằm trên sổ giấy, không thống kê được.

1.2.2. Khảo sát người dùng

Đề tài xác định **ba nhóm người dùng** với nhu cầu khác hẳn nhau.

Nhóm	Cần gì	Hệ quả thiết kế
Khách vắng lai — chiếm đa số	Xem phòng, biết giá, đặt được phòng; không muốn tạo tài khoản	Tài khoản là tuỳ chọn , không phải điều kiện. Bắt đăng ký trước khi đặt là chỗ mất khách nhiều nhất của một trang đặt phòng
Khách có tài khoản	Mọi thao tác của khách vắng lai, thêm việc xem lại toàn bộ đơn ở một nơi	Một màn hình danh sách đơn của riêng tài khoản
Quản trị viên — chủ homestay và nhân viên	Nhìn thấy toàn bộ đơn, xử lý tiên, cập nhật thông tin phòng; dùng hằng ngày	Khu quản trị ưu tiên mật độ thông tin cao hơn tính thẩm mỹ

1.3. Khảo sát các hệ thống tương tự

Đề tài khảo sát hai nền tảng đặt phòng lớn nhất tại thị trường Việt Nam là Booking.com và Agoda, cùng mô hình Airbnb cho phân khúc lưu trú cá nhân.

Hình 1.3 thể hiện trang kết quả tìm kiếm của Booking.com với bốn thành phần được phân tích: thanh tìm kiếm cố định, thẻ phòng, tổng tiền cả kỳ và nhân khan hiếm.

[CHUA CO HINH 1.3]

1.3.1. So sánh với hệ thống của đề tài

Điểm khác biệt căn bản: ba nền tảng trên là **sàn trung gian nhiều cơ sở**, thu hoa hồng 15–20% mỗi đơn, còn hệ thống của đề tài phục vụ **một cơ sở duy nhất** và không thu hoa hồng. Về chức năng, đề tài giữ những điểm mạnh đã được kiểm chứng của cả ba: cho đặt phòng không cần tài khoản, hiển thị tổng tiền cả kỳ ở mọi bước, và chặn sẵn ngày hết phòng ngay trong lịch chọn ngày. Khác biệt về thanh toán: ba nền tảng dùng

thẻ, đề tài dùng chuyển khoản mã QR — phù hợp với thói quen thanh toán trong nước và không đòi hỏi tài khoản cổng thanh toán quốc tế.

1.3.2. Mẫu thiết kế áp dụng và mẫu cố ý không áp dụng

Đề tài áp dụng các mẫu thiết kế đã được kiểm chứng qua nghiên cứu hành vi người dùng trên nền tảng đặt chỗ lưu trú [1], nhưng **từ chối** nhóm mẫu gây áp lực giả được phân tích trong khảo sát đối sánh hai nền tảng [10].

Cụ thể, đề tài giữ lại nhãn "còn N phòng" nhưng buộc con số đó lấy trực tiếp từ cơ sở dữ liệu, có ràng buộc loại trừ bảo chứng là đúng. Đồng hồ đếm ngược chỉ dùng cho hạn giữ chỗ **có thật** trong cơ sở dữ liệu, không phải để thúc ép. Và hệ thống **không hiển thị số người đang xem** — vì hệ thống không đo được số đó.

Luận điểm: các nhãn khan hiếm trên nền tảng lớn thường không tương ứng với dữ liệu thật. Đồ án giữ lại hình thức của chúng, vì chúng thật sự giúp khách quyết định nhanh, nhưng buộc mọi con số phải có nguồn gốc kiểm chứng được. Lựa chọn này khả thi chính vì ràng buộc ở tầng cơ sở dữ liệu bảo đảm con số phòng còn trống luôn đúng.

1.4. Xác định yêu cầu

1.4.1. Yêu cầu chức năng

Đề tài xác định **32 yêu cầu chức năng** chia ba nhóm theo tác nhân:

Nhóm	Mã	Số lượng	Nội dung chính
A — Khách	CN-01...CN-14	14	Xem loại phòng và tiện nghi; tìm phòng theo ngày; xem lịch từng đêm; gửi yêu cầu đặt phòng; xem chi phí dự kiến; áp mã khuyến mãi; thanh toán mã QR; tra cứu và huỷ đơn; nhận thư xác nhận; viết đánh giá; đăng ký và xem lại đơn; đọc tin tức
B — Quản trị viên	CN-15...CN-28	14	Đăng nhập và buộc đổi mật khẩu tạm; quản lý đơn và chuyển trạng thái; ghi chú nội bộ; đối soát thanh toán; quản lý loại phòng, phòng vật lý, ngày khả dụng , khuyến

Nhóm	Mã	Số lượng	Nội dung chính
			mãi, đánh giá, nội dung trang chủ; xem tổng quan; xuất báo cáo CSV
C — Hệ thống tự động	CN-29...CN-32	4	Nhận webhook và tự xác nhận đơn; quét đơn quá hạn và nhả phòng; gửi thư qua hàng đợi; xử lý tiền về muộn

Danh sách chi tiết từng yêu cầu trình bày ở Phụ lục K.

1.4.2. Yêu cầu phi chức năng

Mười hai yêu cầu phi chức năng chia theo năm loại: **toàn vẹn** ba yêu cầu, **bảo mật** ba, **khả dụng** ba, **hiệu năng** một, **triển khai** một và **bảo trì** một. Mỗi yêu cầu đi kèm một cách kiểm chứng cụ thể chứ không phải một lời hứa — ví dụ "không bao giờ bán trùng một phòng" được kiểm bằng ca kiểm thử đa luồng thật, "mặc định từ chối mọi endpoint chưa khai quyền" được kiểm bằng ma trận ba mươi tiên tố đường dẫn. Bảng đầy đủ mười hai yêu cầu kèm cách kiểm chứng trình bày ở Phụ lục O.

1.5. Phạm vi và giới hạn của hệ thống

Trong phạm vi: toàn bộ 32 yêu cầu chức năng và 12 yêu cầu phi chức năng nêu trên, đã cài đặt và kiểm thử.

Ngoài phạm vi và lý do:

Không có	Lý do
Cổng thanh toán thật	Đề tài không yêu cầu; hệ thống viết đúng luồng thật, chỉ thiếu tài khoản thật
Hoàn tiền tự động	Hoàn tiền là quyết định kinh doanh; hệ thống đưa vào hàng đợi cho người xử lý
Ứng dụng di động	Website đã đáp ứng; xây dựng ứng dụng di động là một đề tài riêng
Nhiều chi nhánh	Bài toán khác hẳn về mô hình dữ liệu
Giao thức HTTPS trong bản đóng gói	Cần tên miền và chứng chỉ thật; đây là giới hạn đã biết, trình bày ở mục 5.7

CHƯƠNG 2. NGHIÊN CỨU LÝ THUYẾT

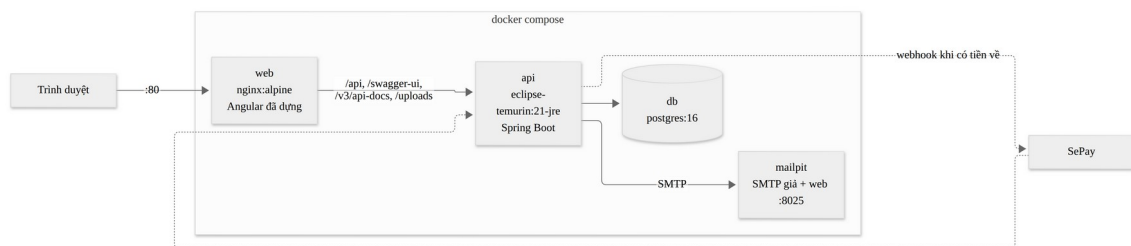
2.1. Kiến trúc ứng dụng web tách rời

2.1.1. Mô hình khách — chủ và giao diện lập trình ứng dụng REST

Hệ thống theo kiến trúc **tách rời**: tầng giao diện và tầng máy chủ là hai ứng dụng độc lập, giao tiếp qua giao diện lập trình ứng dụng trả về dữ liệu định dạng JSON. Tầng giao diện không truy cập cơ sở dữ liệu; tầng máy chủ không sinh HTML.

So với kiến trúc nguyên khối kết xuất phía máy chủ, kiến trúc tách rời phức tạp hơn lúc khởi đầu và cần thêm công sức tối ưu công cụ tìm kiếm. Đối lại, hệ thống có **hai giao diện rất khác nhau** — trang bán hàng cho khách và khu quản trị mật độ cao — dùng chung **một** giao diện lập trình ứng dụng. Chính giao diện đó cũng dùng lại được nguyên vẹn nếu sau này phát triển ứng dụng di động, nên chi phí phức tạp ban đầu được bù lại.

Hình 2.1 thể hiện kiến trúc tổng thể của hệ thống khi triển khai.



Hình 2.1 — Kiến trúc tổng thể của hệ thống khi triển khai (Nguồn: tác giả)

2.1.2. Nguyên tắc REST áp dụng trong đề tài

- **Tài nguyên là danh từ, thao tác là động từ HTTP.** Ví dụ GET /api/room-types, POST /api/bookings, PATCH /api/admin/rooms/{id}.
- **Tài nguyên con lồng vào tài nguyên cha.** Ví dụ GET /api/admin/rooms/{id}/closures — khoảng đóng phòng không tồn tại độc lập với phòng.
- **Mã trạng thái HTTP mang ngữ nghĩa.** Mã 201 khi tạo mới, 204 khi xóa thành công, 409 khi xung đột trạng thái, 429 khi vượt giới hạn tần suất.
- **Lỗi theo chuẩn RFC 7807 [4].** Mọi phản hồi lỗi có cấu trúc thống nhất kèm trường code do hệ thống tự thêm. Tầng giao diện đọc trường code, không đọc câu chữ mô tả, nên việc sửa câu chữ ở tầng máy chủ không làm hỏng màn hình.

2.2. Ngôn ngữ và nền tảng tầng máy chủ

2.2.1. Java 21

Java 21 là phiên bản hỗ trợ dài hạn. Đề tài sử dụng ba tính năng ngôn ngữ: kiểu record cho toàn bộ đối tượng truyền dữ liệu, bảo đảm tính bất biến và không thể vô tình bị sửa giữa các tầng; lớp niêm phong *sealed* cho cây ngoại lệ nghiệp vụ, giúp trình biên dịch báo ngay khi thêm một loại lỗi mới mà quên xử lý; và khối văn bản để viết các câu truy vấn SQL nhiều dòng còn đọc được.

2.2.2. Spring Boot 3.5.6

Spring Boot là nền tảng xây dựng ứng dụng Java theo mô hình cấu hình sẵn, giảm lượng cấu hình thủ công mà nhà phát triển phải viết [11]. Các mô-đun được đề tài sử dụng:

Mô-đun	Vai trò trong đề tài
Spring Web MVC	Tầng điều khiển, ánh xạ REST
Spring Data JPA	Truy cập dữ liệu qua Hibernate cho phân thao tác cơ bản
Spring JDBC	Các truy vấn phòng trống viết SQL thuần (lý do ở mục 2.4.3)
Spring Security	Xác thực bằng token, phân quyền theo vai trò
Spring Validation	Kiểm tra dữ liệu đầu vào bằng chú thích
Spring Mail	Gửi thư xác nhận
Spring Scheduling	Bộ quét đơn quá hạn, bộ gửi thư

2.2.3. Giao dịch và hành vi huỷ giao dịch

Một giao dịch cơ sở dữ liệu có bốn tính chất ACID: tính nguyên tử, tính nhất quán, tính cô lập và tính bền vững.

Điểm mà đề tài buộc phải hiểu sâu là **hành vi huỷ giao dịch**. Khi PostgreSQL bác một câu lệnh vì vi phạm ràng buộc, **toàn bộ giao dịch bị đánh dấu hỏng**. Mọi câu lệnh tiếp theo trong cùng giao dịch đó trả về mã lỗi 25P02 chứ không thực thi. Spring Framework cũng đánh dấu giao dịch chỉ được huỷ khi gặp ngoại lệ thời gian chạy [12].

Hệ quả trực tiếp lên thiết kế: vòng thử gán phòng tiếp theo **bắt buộc** phải chạy trong một giao dịch mới. Chi tiết cài đặt ở mục 4.3.2.

2.2.4. Hibernate và chế độ kiểm tra lược đồ

Đề tài đặt `spring.jpa.hibernate.ddl-auto = validate` và không bao giờ dùng `update`.

Chế độ `update` để Hibernate tự sửa lược đồ. Nó âm thầm thêm cột, không bao giờ xóa cột thừa, và không ghi lại những thay đổi đã thực hiện. Sau một thời gian, lược đồ máy phát triển và trên máy chạy thật khác nhau mà không có cách nào biết khác ở chỗ nào.

Chế độ `validate` chỉ **kiểm tra**: mọi cột mà thực thể khai báo phải tồn tại đúng kiểu trong cơ sở dữ liệu. Ứng dụng khởi động được nghĩa là **20 thực thể** khớp hoàn toàn với lược đồ do Flyway dựng ra.

2.3. Ngôn ngữ và nền tảng tầng giao diện

Tầng giao diện dùng **Angular 21** với ba đặc điểm: component độc lập, không còn khái niệm mô-đun [2]; cơ chế phản ứng signals, đủ cho quy mô này nên đề tài không dùng thư viện quản lý trạng thái bên ngoài; và nạp lười theo tuyến, nhờ đó người truy cập trang đặt phòng không phải tải mã của mười một màn hình quản trị.

Về định kiểu, đề tài **không dùng thư viện giao diện dựng sẵn** mà tự xây thư viện component trên nền **Tailwind CSS 4**. Lý do: thư viện dựng sẵn mang theo ngôn ngữ thị giác của nó, làm trang web mang dáng dấp ứng dụng gốc chứ không giống một trang đặt phòng. Tự xây cho phép kiểm soát hoàn toàn bảng màu, khoảng cách và trạng thái.

Một khái niệm cần nắm là **tầng CSS**: Tailwind 4 đặt các lớp tiện ích trong tầng `utilities`, và một quy tắc CSS không nằm trong tầng nào luôn thắng mọi quy tắc nằm trong tầng, bất kể độ ưu tiên. Đây là nguồn gốc của một lỗi thật gặp phải trong quá trình thực hiện, trình bày ở mục 4.3.

2.4. Hệ quản trị cơ sở dữ liệu PostgreSQL 16

Đây là mục quan trọng nhất của chương. Toàn bộ lời giải cho bài toán cốt lõi nằm ở đây.

2.4.1. Mức cô lập giao dịch và giới hạn của nó

PostgreSQL mặc định chạy ở mức cô lập **Read Committed** [9]. Ở mức này, một câu `SELECT` chỉ thấy ảnh chụp dữ liệu tại **thời điểm câu lệnh đó bắt đầu chạy** — nó chỉ

thấy dữ liệu đã được commit trước đó, không thấy thay đổi chưa commit của giao dịch song song.

Điều quan trọng là: **Read Committed không ngăn được hai giao dịch song song cùng đọc rồi cùng ghi**. Tài liệu PostgreSQL nêu rõ ví dụ một giao dịch cập nhật giá trị trong khi giao dịch khác đang tìm theo giá trị cũ, dẫn tới kết quả không như mong đợi [9].

Nâng lên mức **Repeatable Read** thì mọi câu lệnh trong cùng giao dịch dùng chung một ảnh chụp tại thời điểm bắt đầu giao dịch, ngăn được hiện tượng đọc ảo. Mức **Serializable** ngăn thêm được bất thường tuần tự hoá, nhưng đánh đổi bằng việc giao dịch có thể bị bác với mã lỗi 40001 và ứng dụng phải thử lại toàn bộ từ đầu [9].

Điểm mấu chốt cho đề tài: **ngay cả ở mức Serializable, tài liệu PostgreSQL vẫn khuyến cáo không dựa vào việc kiểm tra ở tầng ứng dụng trước khi ghi**. Tài liệu nêu rõ vẫn có thể gặp vi phạm ràng buộc duy nhất do xung đột giữa các giao dịch chồng lấn, kể cả sau khi đã kiểm tra tường minh rằng khoá chưa tồn tại [9]. Khuyến nghị là **sử dụng ràng buộc toàn vẹn** thay vì kiểm tra ở tầng ứng dụng.

Đây chính là căn cứ lý thuyết cho toàn bộ thiết kế của đồ án.

2.4.2. Kiểu dữ liệu khoảng

PostgreSQL có kiểu `daterange` biểu diễn một khoảng ngày như một giá trị duy nhất, kèm toán tử `&&` kiểm tra hai khoảng có giao nhau hay không [8]:

```
SELECT daterange('2026-03-08', '2026-03-10', '[)')
       && daterange('2026-03-10', '2026-03-12', '[)');    -- false, không
giao nhau
```

Ký hiệu `'[)'` là **khoảng nửa mở**: bao gồm cận dưới, không bao gồm cận trên. Ngữ nghĩa này trùng khớp với nghiệp vụ lưu trú, và đây là lý do quy ước nửa mở được lựa chọn.

2.4.3. Ràng buộc loại trừ

```
ALTER TABLE booking_rooms
ADD CONSTRAINT booking_rooms_no_overlap
EXCLUDE USING gist (room_id WITH =, stay WITH &&)
WHERE (status = 'ACTIVE');
```

Ràng buộc trên đọc là: không được phép tồn tại hai dòng có cùng `room_id` và có `stay` giao nhau, trong số các dòng đang ở trạng thái `ACTIVE`.

Ba lý do ràng buộc này là lời giải đúng:

Thứ nhất, nó đóng khe hở tranh chấp. Cách làm quen thuộc là kiểm tra rồi ghi:

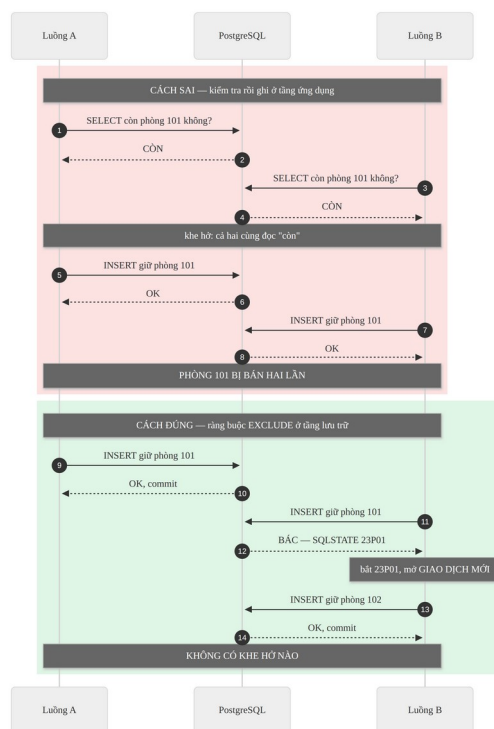
```
SELECT ... WHERE NOT EXISTS (đơn nào giao ngày không?)    -- kiểm tra
INSERT INTO booking_rooms ...                                -- rồi ghi
```

Giữa hai câu lệnh đó có một khoảng thời gian. Hai giao dịch song song cùng đọc kết quả còn phòng rồi cùng ghi, và phòng bị bán hai lần. Mẫu này sai về nguyên lý như đã phân tích ở mục 2.4.1, không phải sai vì viết ầu.

Phương án khoá bi quan bị được khe hở nhưng biến mọi lượt đặt cùng một loại phòng thành hàng đợi một luồng, và không còn đúng khi ứng dụng chạy nhiều bản song song.

Với ràng buộc loại trừ, PostgreSQL bác một trong hai giao dịch ngay trong động cơ lưu trữ, bằng mã lỗi SQLSTATE 23P01. Không còn khe hở nào để chen vào.

Hình 2.2 so sánh trực quan hai cách xử lý tranh chấp.



Hình 2.2 (Nguồn: tác giả)

Thứ hai, nó đúng ngữ nghĩa nửa mở mà không cần một dòng mã ứng dụng nào.

Thứ ba, nó cho phép huỷ đơn nhả phòng ngay mà vẫn giữ lịch sử. Mệnh đề WHERE (status = 'ACTIVE') làm ràng buộc chỉ xét những dòng đang giữ chỗ. Huỷ đơn chỉ đổi trạng thái sang RELEASED: phòng mở lại lập tức, dòng dữ liệu vẫn còn để tra cứu.

2.4.4. Chỉ mục GiST và phần mở rộng btree_gist

Ràng buộc loại trừ cần một chỉ mục hỗ trợ toán tử &&. Chỉ mục B-tree thông thường được thiết kế cho dữ liệu vô hướng và **chỉ hỗ trợ so sánh tuyến tính** — bằng, lớn hơn, nhỏ hơn. Nó không trả lời được câu hỏi hai khoảng có giao nhau hay không.

GiST là viết tắt của Generalized Search Tree — cây tìm kiếm tổng quát. Tài liệu PostgreSQL định nghĩa nó là một phương thức truy cập có cấu trúc cây cân bằng, đóng vai trò khuôn mẫu cơ sở để cài đặt các lược đồ đánh chỉ mục tùy ý [7].

Điểm khác biệt cốt lõi so với B-tree: B-tree có cấu trúc cố định dựa trên thứ tự tuyến tính, còn GiST cho phép định nghĩa **lớp toán tử tùy chỉnh** cho từng kiểu dữ liệu. Nhờ đó GiST xử lý được các phép toán như giao nhau, bao hàm, khoảng cách — những phép toán không quy về được thứ tự tuyến tính [7].

Ràng buộc của đề tài trộn hai toán tử: `room_id WITH` = thuộc về B-tree và `stay WITH &&` thuộc về GiST. Phần mở rộng ``btree_gist`` cho phép đưa cả hai vào một chỉ mục GiST duy nhất. Đây là lý do migration đầu tiên của hệ thống bắt đầu bằng câu lệnh tạo phần mở rộng này.

2.4.5. Cột sinh tự động

```
stay daterange GENERATED ALWAYS AS (daterange(check_in, check_out,
'[]')) STORED
```

Cột `stay` không bao giờ được ghi trực tiếp; PostgreSQL tự tính từ hai cột ngày. Nếu để tầng ứng dụng tự tính rồi ghi vào, sẽ có lúc nó tính sai — và lúc đó ràng buộc đang canh một giá trị sai, tức là không canh gì cả.

2.4.6. Trigger ràng buộc hoãn

Hệ thống có một bất biến thứ hai: **số phòng đã gán phải khớp số phòng đơn yêu cầu**. Bất biến này không kiểm được bằng ràng buộc CHECK vì nó liên quan tới hai bảng.

Nếu kiểm tra ngay sau mỗi câu lệnh chèn, một đơn đặt hai phòng sẽ bị bác ngay sau dòng đầu tiên, vì lúc đó mới có một phòng trong khi đơn yêu cầu hai. Giải pháp là `CONSTRAINT TRIGGER ... DEFERRABLE INITIALLY DEFERRED`: PostgreSQL hoãn việc kiểm tra tới **thời điểm commit**, khi mọi dòng đã ghi xong.

2.5. Xác thực và phân quyền bằng JSON Web Token

JSON Web Token là chuỗi ký tự gồm phần đầu, phần tải và chữ ký, đã ký bằng khoá bí mật của máy chủ. Máy chủ không cần lưu phiên làm việc, chỉ cần xác minh chữ ký.

Đề tài dùng **hai loại token với hai vòng đời**: token truy cập sống ngắn, lưu trong bộ nhớ của trang và gửi kèm mỗi yêu cầu; token làm mới sống dài, lưu trong cookie mà mã kịch bản không đọc được. Tách đôi như vậy vì token truy cập có thể bị mã độc chèn vào trang lấy được, nhưng nó hết hạn sau vài phút; còn token làm mới sống lâu thì nằm ngoài tầm với của mã kịch bản.

Nhược điểm cố hữu của JWT là không thu hồi được trước hạn. Đề tài khắc phục bằng một **số phiên bản** lưu trong bảng người dùng và nhúng vào token: khi đổi mật khẩu hoặc đăng xuất, số đó tăng lên và mọi token cũ mất hiệu lực ngay.

2.6. Quản lý phiên bản lược đồ bằng Flyway

Flyway thực thi các tệp SQL đánh số theo thứ tự và ghi lại tệp nào đã chạy kèm giá trị băm của nó. Nguyên tắc **bất biến**: migration đã phát hành không bao giờ được sửa, vì sửa làm giá trị băm thay đổi và Flyway chặn khởi động. Muốn đổi lược đồ thì thêm một migration mới. Hệ thống hiện có tám migration.

Dữ liệu mẫu **cố ý không đi qua Flyway**. Nếu dữ liệu minh hoạ là một migration, việc chuyển sang môi trường thật trên cùng khối dữ liệu sẽ mang theo cả 40 đơn giả. Dữ liệu mẫu được nạp bởi một thành phần riêng chỉ kích hoạt ở cấu hình trình diễn.

2.7. Đóng gói bằng Docker và Docker Compose

Ảnh Docker là bản đóng gói gồm ứng dụng và mọi thành phần nó cần để chạy. Đề tài dùng **tệp Dockerfile nhiều tầng**: tầng đầu chứa công cụ biên dịch, tầng sau chỉ chứa kết quả biên dịch, nên ảnh cuối không mang theo trình biên dịch và có ít bề mặt tấn công hơn. Docker Compose mô tả nhiều dịch vụ trong một tệp cấu hình.

Hệ thống gồm bốn dịch vụ: máy chủ web, ứng dụng, cơ sở dữ liệu và máy chủ thư giả lập. **Chỉ máy chủ web và giao diện xem thư mở cổng ra máy chủ**; ứng dụng và cơ sở dữ liệu không mở cổng nào, và đây là điều kiện để tin được thông tin địa chỉ mà máy chủ web chuyển tiếp, giải thích ở mục 3.9.3.

2.8. Thanh toán qua mã QR và webhook

VietQR là chuẩn mã QR thanh toán của hệ thống ngân hàng Việt Nam. Quét mã điền sẵn số tài khoản, số tiền và nội dung chuyển khoản.

SePay là dịch vụ trung gian đọc biến động số dư của tài khoản ngân hàng và gọi webhook tới hệ thống khi có tiền về [14].

Webhook là cơ chế ngược với việc hỏi liên tục: thay vì hệ thống hỏi có tiền chưa mỗi vài giây, nhà cung cấp chủ động gọi vào một endpoint do hệ thống cung cấp.

Ba vấn đề kỹ thuật phải giải quyết:

Vấn đề	Cách giải quyết
Bất kỳ ai cũng gọi được endpoint webhook	Xác thực bằng khoá trong phần đầu yêu cầu
Nhà cung cấp có thể gửi lại cùng một sự kiện	Ràng buộc duy nhất trên cặp nhà cung cấp và mã sự kiện — gửi lại không cộng tiền hai lần
Tiền về sau khi đơn đã hết hạn	Mở lại đơn sang trạng thái chờ đối soát, thử giành lại phòng; không được thì vào hàng đợi hoàn tiền

2.9. Kiểm thử với Testcontainers

Testcontainers khởi động một container Docker thật trong lúc chạy kiểm thử. Đề tài bắt buộc dùng nó vì phần lớn nội dung đáng kiểm thử ở hệ thống này **chính là hành vi của cơ sở dữ liệu**: ràng buộc loại trừ, kiểu khoảng, trigger hoãn, mã trạng thái SQL. Cơ sở dữ liệu trong bộ nhớ không có những tính năng đó, nên kiểm thử chạy trên nền giả lập sẽ thành công mà không chứng minh được điều duy nhất đáng chứng minh.

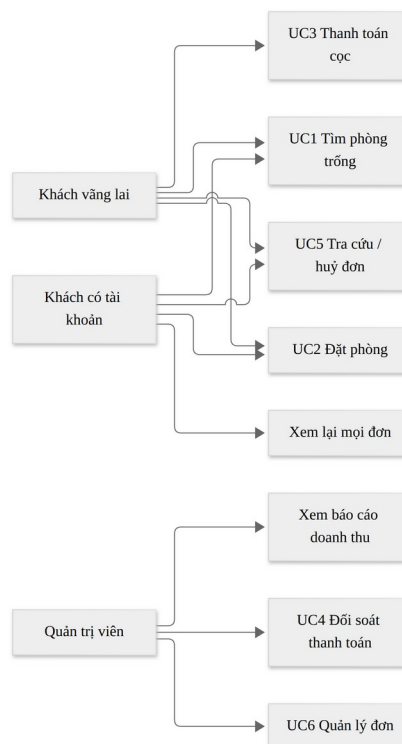
CHƯƠNG 3. HIỆN THỰC HÓA NGHIÊN CỨU

3.1. Phân tích chức năng — biểu đồ use case

3.1.1. Xác định tác nhân

Tác nhân	Mô tả	Cơ chế xác thực
Khách vắng lai	Không có tài khoản. Đặt, tra cứu và huỷ đơn bằng mã đơn và số điện thoại	Không đăng nhập. Thao tác trên một đơn cụ thể cần mã đơn và số điện thoại, hoặc mã truy cập trong liên kết thư xác nhận
Khách có tài khoản	Thực hiện được mọi thao tác của khách vắng lai, thêm việc xem lại mọi đơn ở một nơi	Token, vai trò CUSTOMER
Quản trị viên	Chủ homestay và nhân viên	Token, vai trò ADMIN
<i>Tác nhân hệ thống</i>	Nhà cung cấp thanh toán gọi webhook; bộ quét định kỳ	Khoá trong phân đầu yêu cầu, hoặc nội bộ

Hình 3.1 thể hiện biểu đồ use case tổng quát của hệ thống.



Hình 3.1 — Biểu đồ use case tổng quát của hệ thống (Nguồn: tác giả)

3.1.2. Danh sách use case

Mã	Tên use case	Tác nhân chính
UC1	Tìm phòng trống	Khách vắng lai, Khách có tài khoản
UC2	Đặt phòng	Khách vắng lai, Khách có tài khoản
UC3	Thanh toán cọc	Khách vắng lai, Khách có tài

Mã	Tên use case	Tác nhân chính
		khoản
UC4	Đối soát thanh toán	Quản trị viên
UC5	Tra cứu và huỷ đơn	Khách vắng lai, Khách có tài khoản
UC6	Quản lý đơn đặt phòng	Quản trị viên
UC7	Xem lại toàn bộ đơn đã đặt	Khách có tài khoản
UC8	Xem báo cáo doanh thu	Quản trị viên
UC9	Đặt ngày khả dụng của phòng	Quản trị viên
UC10	Soạn nội dung trang chủ	Quản trị viên
UC11	Viết đánh giá	Khách đã trả phòng

3.1.3. Đặc tả use case

Đặc tả đầy đủ của **cả mười một use case** — tác nhân, tiền điều kiện, luồng chính, luồng thay thế, hậu điều kiện — trình bày ở Phụ lục A. Hai use case trọng tâm là UC1 *Tìm phòng trống* và UC2 *Đặt phòng*: UC1 là nơi truy vấn còn phòng chạy, UC2 là nơi ràng buộc loại trừ của cơ sở dữ liệu ra quyết định cuối cùng khi hai khách cùng đặt một phòng.

3.2. Thiết kế cơ sở dữ liệu

3.2.1. Tổng quan

Lược đồ gồm **21 bảng nghiệp vụ**, dựng bởi **tám migration** Flyway từ V1 tới V8. Bảng thứ 22 trong lược đồ công khai là sổ ghi chép của chính Flyway, không thuộc mô hình nghiệp vụ.

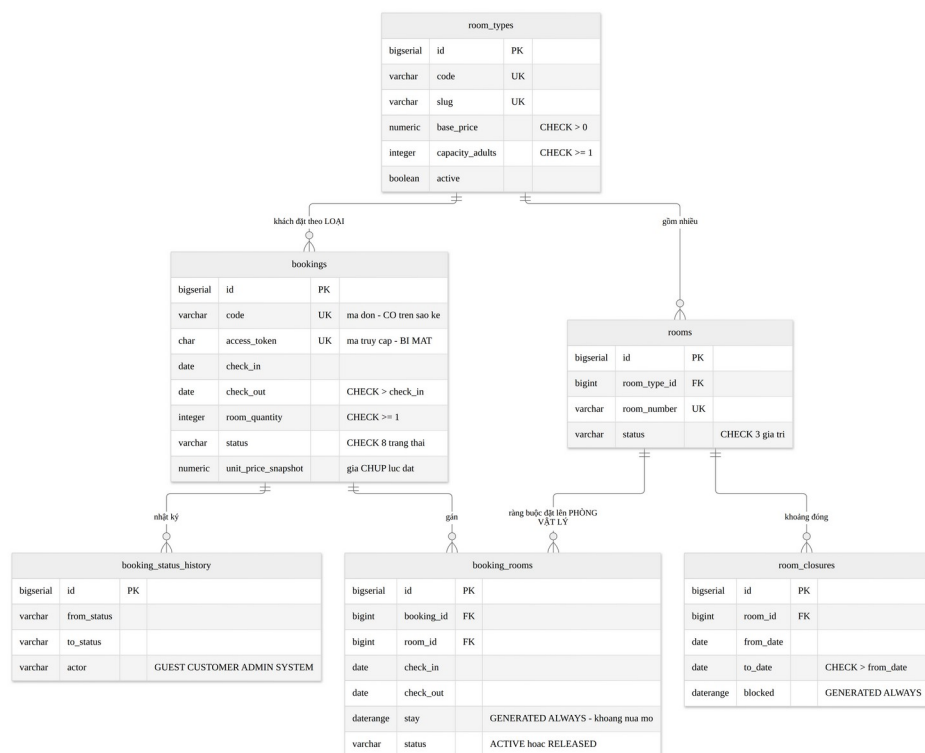
Hình 3.2 thể hiện sơ đồ quan hệ thực thể tổng thể.



Hình 3.2 — Sơ đồ quan hệ thực thể tổng thể (Nguồn: tác giả)

Nhóm	Migration	Các bảng	Vai trò
Người dùng và xác thực	V1	users, refresh_tokens	Tài khoản, vai trò, phiên đăng nhập
Phòng và tiện nghi	V2	amenities, room_types, rooms, room_type_images, room_type_amenities	Danh mục sản phẩm
Đặt phòng	V3	bookings, booking_rooms, booking_status_history	Lỗi nghiệp vụ
Thanh toán và thư	V4	payments, payment_webhook_events, outbound_emails	Tiền và liên lạc
Khuyến mãi và đánh giá	V5	promotions, reviews	Tiếp thị và uy tín
Nội dung	V6	site_contents, banners, gallery_images, posts	Trang chủ, tin tức
Ghi chú nội bộ	V7	booking_notes	Trao đổi nội bộ trên đơn
Ngày khả dụng	V8	room_closures	Khoảng ngày phòng không nhận khách

Hình 3.3 thể hiện chi tiết nhóm bảng đặt phòng, nơi đặt ràng buộc quan trọng nhất của hệ thống.



Hình 3.3 — Chi tiết nhóm bảng đặt phòng, nơi đặt ràng buộc quan trọng (Nguồn: tác giả)

3.2.2. Mô tả bốn bảng cốt lõi

Bốn bảng dưới đây mang các ràng buộc quyết định của hệ thống; phần này giải thích **vì sao** mỗi ràng buộc tồn tại. Danh sách cột đầy đủ của cả 21 bảng, theo mẫu ba cột tên cột – kiểu – mô tả và ràng buộc, trình bày ở Phụ lục B.

Bảng `users` — tài khoản người dùng

Ràng buộc `ck_users_email_lower` buộc lưu email chữ thường ở **tầng dữ liệu** thay vì phó mặc cho tầng ứng dụng. Chỉ cần một chỗ quên chuẩn hoá là tạo được hai tài khoản cho cùng một hộp thư.

Bảng `bookings` — đơn đặt phòng

Bốn cột kết thúc bằng `_snapshot` lưu bản sao giá trị tại thời điểm đặt. Khi quản trị viên đổi giá hoặc đổi tên loại phòng sau này, đơn cũ vẫn giữ nguyên số tiền và tên mà khách đã nhìn thấy lúc đặt.

Bảng `booking\_rooms` — gán phòng vật lý cho đơn

Ràng buộc quyết định của toàn hệ thống nằm trên bảng này:

```
EXCLUDE USING gist (room_id WITH =, stay WITH &&) WHERE (status = 'ACTIVE')
```

Bảng này còn mang hai trigger ràng buộc hoàn bảo đảm số dòng ACTIVE luôn khớp room_quantity của đơn, đặt ở cả hai phía: khi sửa booking_rooms và khi sửa room_quantity trên bookings.

Bảng `room\_closures` — khoảng ngày phòng không nhận khách

Ràng buộc room_closures_no_overlap chống hai khoảng đóng chồng nhau trên cùng một phòng.

3.2.3. Hai lần sử dụng ràng buộc loại trừ

Cùng một cơ chế được sử dụng cho hai bài toán khác nhau, cho thấy lựa chọn PostgreSQL không nhằm phục vụ một trường hợp duy nhất.

Lần	Bảng	Ràng buộc	Chống điều gì
1	booking_rooms	booking_rooms_no_overlap	Hai đơn cùng giữ một phòng trong những ngày giao nhau
2	room_closures	room_closures_no_overlap	Hai khoảng đóng chồng nhau trên cùng một phòng

Lần thứ hai giải quyết một lỗi rất khó chẩn đoán từ phía người dùng. Nếu cho phép hai khoảng đóng chồng nhau, màn hình quản trị hiển thị hai dòng mô tả cùng một điều, và việc xoá một dòng **không mở lại được phòng**: người dùng nhấn xoá, thấy dòng biến mất, rồi vẫn không bán được phòng mà không có cách nào hiểu vì sao.

Khác biệt giữa hai ràng buộc: booking_rooms_no_overlap có mệnh đề điều kiện WHERE (status = 'ACTIVE') vì dòng gán phòng có trạng thái và cần giữ lịch sử; room_closures_no_overlap không có, vì khoảng đóng không có trạng thái và xoá là xoá hẳn.

3.2.4. Chuẩn hoá dữ liệu

Lược đồ đạt **dạng chuẩn 3**. Hai điểm đáng nêu:

Tách `room\_types` và `rooms` là quyết định mô hình hoá quan trọng nhất. Khách đặt một **loại phòng**, nhưng ràng buộc chống trùng lịch phải đặt lên **phòng vật lý**. Gộp hai khái niệm vào một bảng thì hoặc không chống trùng được, hoặc buộc khách phải chọn đúng số phòng — điều không nên tảng đặt phòng nào thực hiện.

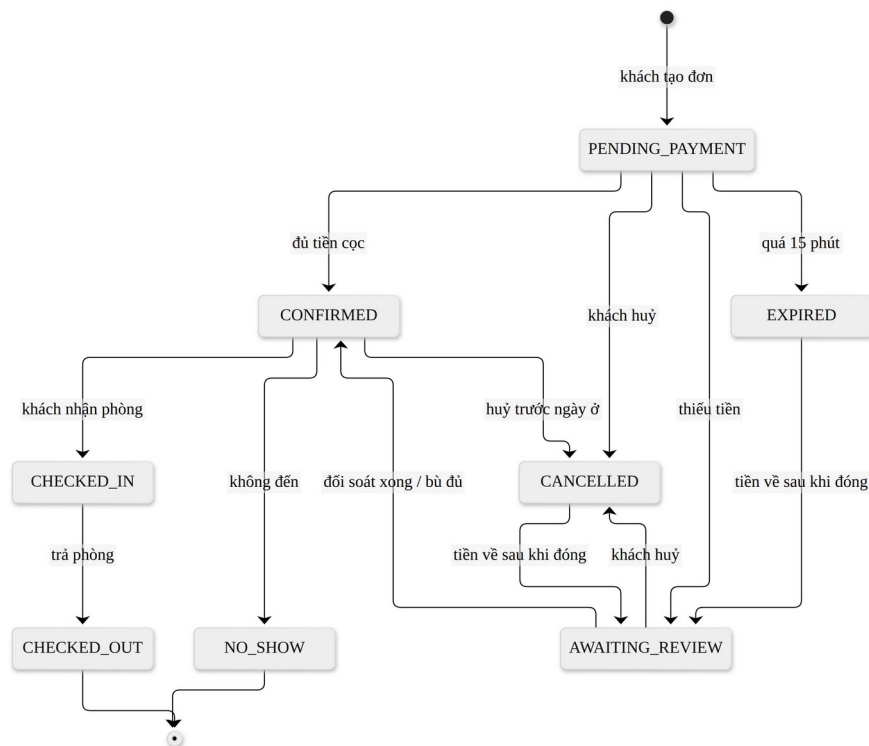
Các chỗ cố ý phi chuẩn hoá. Cột guest_name_snapshot trong bảng reviews và bốn cột kết thúc bằng _snapshot trong bảng bookings lưu bản sao giá trị tại thời

3.3.2. Máy trạng thái đơn đặt phòng

Đơn đặt phòng có **tám trạng thái**. Mọi lần chuyển trạng thái đều đi qua một thành phần duy nhất, vì mỗi lần chuyển kéo theo ba việc phụ để bỏ sót: ghi nhật ký, nhả phòng khi đơn không diễn ra, và hoàn lượt khuyến mãi.

Trạng thái	Ý nghĩa
PENDING_PAYMENT	Vừa tạo, đang giữ chỗ chờ tiền cọc
AWAITING_REVIEW	Có tiền nhưng không khớp, cần người đối soát
CONFIRMED	Đã nhận đủ cọc, phòng được giữ chắc chắn
CHECKED_IN	Khách đã nhận phòng
CHECKED_OUT	Khách đã trả phòng
CANCELLED	Khách hoặc quản trị viên huỷ
EXPIRED	Quá hạn giữ chỗ mà không có tiền
NO_SHOW	Đã xác nhận nhưng khách không đến

Hình 3.5 thể hiện biểu đồ trạng thái đầy đủ, trong đó hai đường chuyển từ CANCELLED và EXPIRED về AWAITING_REVIEW là nhánh xử lý tiền về muộn.



Hình 3.5 — Biểu đồ trạng thái đầy đủ (Nguồn: tác giả)

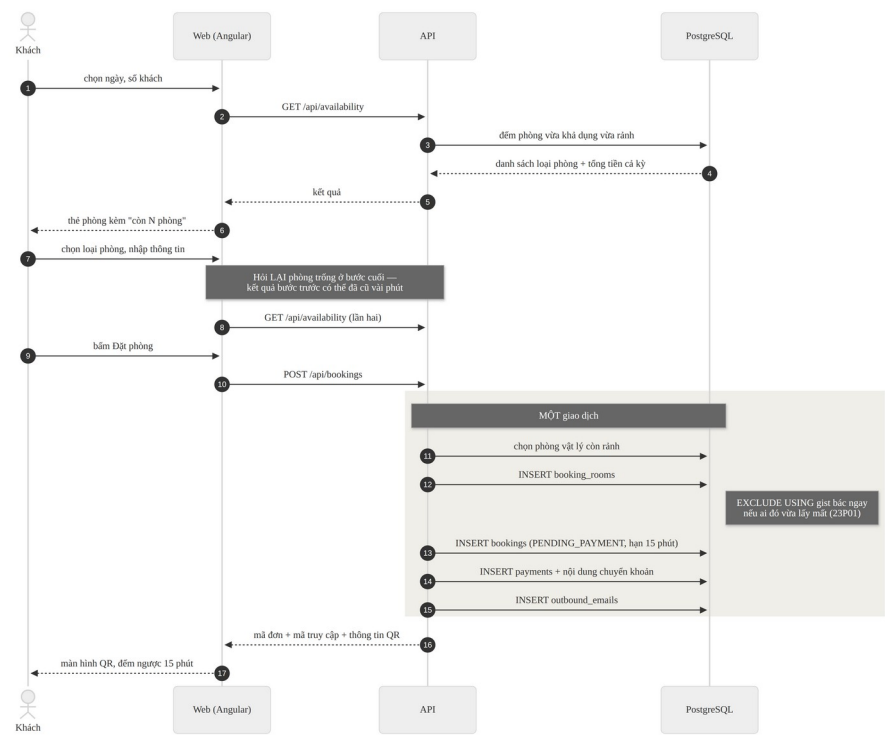
Một quy tắc phản trực giác cần giải thích. Trạng thái CHECKED_OUT **không** nhả phòng. Trực giác cho rằng khách trả phòng thì phòng phải được trả về kho. Nhưng nhả phòng nghĩa là chuyển dòng gán phòng sang RELEASED, trong khi trigger kiểm tra số phòng lại đòi đơn phải luôn giữ đúng số phòng đã đặt — nên nhả phòng lúc trả phòng

làm cơ sở dữ liệu bác cả giao dịch. Quy tắc này phát sinh từ một lỗi thật gặp phải trong quá trình thực hiện, và có một ca kiểm thử riêng canh nó.

3.3.3. Biểu đồ tuần tự

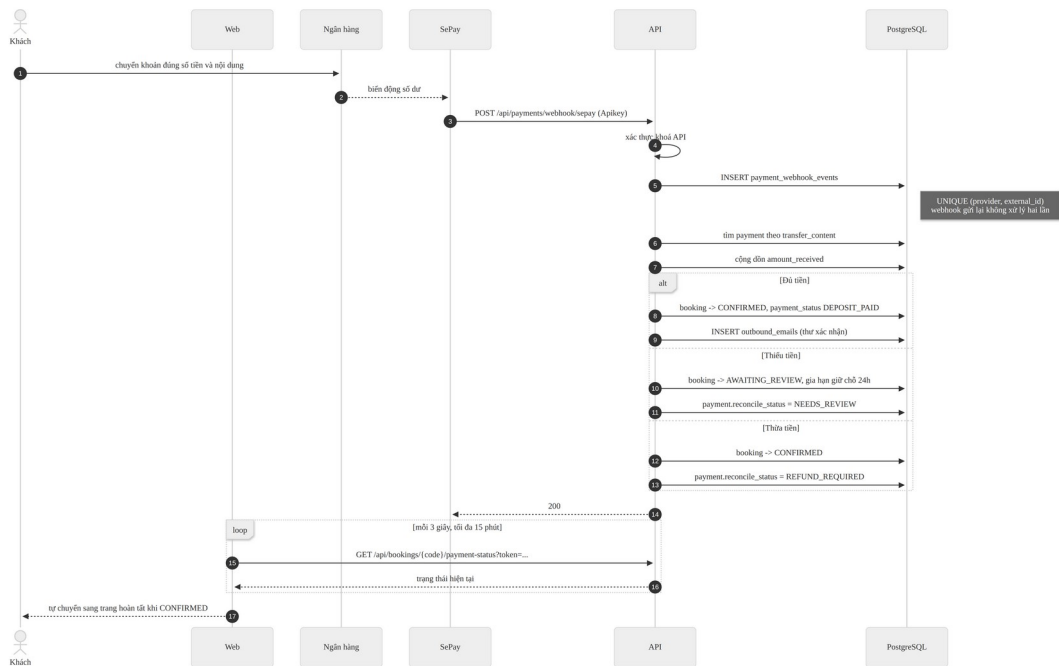
Ba luồng xử lý quan trọng nhất được mô hình hoá bằng biểu đồ tuần tự.

Hình 3.6 thể hiện luồng đặt phòng từ lúc khách chọn ngày tới lúc nhận mã QR, với bốn đối tượng tham gia: khách, trình duyệt, máy chủ ứng dụng và cơ sở dữ liệu.



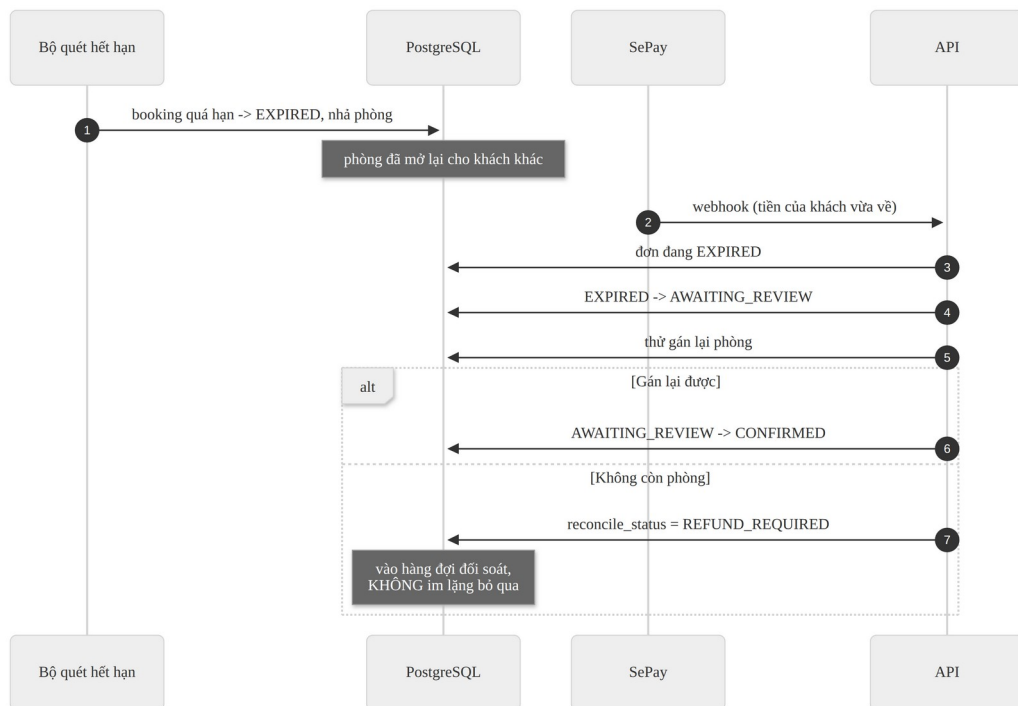
Hình 3.6 — *Luồng đặt phòng từ lúc khách chọn ngày tới lúc nhận mã QR, với (Nguồn: tác giả)*

Hình 3.7 thể hiện luồng thanh toán và webhook, bổ sung hai đối tượng bên ngoài là ngân hàng và nhà cung cấp dịch vụ trung gian.



Hình 3.7 — *Luồng thanh toán và webhook, bổ sung hai đối tượng bên ngoài (Nguồn: tác giả)*

Hình 3.8 thể hiện nhánh tiền về muộn — trường hợp tiền tới sau khi đơn đã hết hạn — cùng hai kết quả có thể xảy ra.

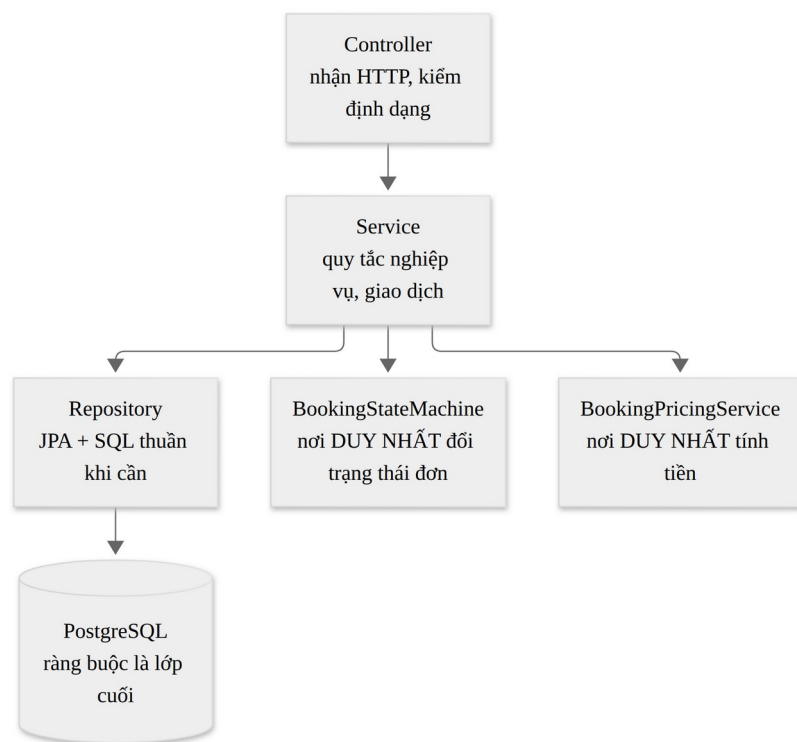


Hình 3.8 — *Nhánh tiền về muộn — trường hợp tiền tới sau khi đơn đã hết (Nguồn: tác giả)*

3.4. Thiết kế kiến trúc phần mềm

3.4.1. Phân lớp tầng máy chủ

Hình 3.9 thể hiện sơ đồ phân lớp của tầng máy chủ.



Hình 3.9 — Sơ đồ phân lớp của tầng máy chủ (Nguồn: tác giả)

Lớp	Trách nhiệm	Không được làm gì
Điều khiển	Nhận yêu cầu HTTP, kiểm tra định dạng đầu vào, ánh xạ sang đối tượng truyền dữ liệu	Không chứa quy tắc nghiệp vụ
Dịch vụ	Quy tắc nghiệp vụ, ranh giới giao dịch	Không biết gì về HTTP
Truy cập dữ liệu	Truy cập cơ sở dữ liệu qua JPA, và SQL thuần khi cần	Không chứa quy tắc nghiệp vụ
Cơ sở dữ liệu	Lớp bảo vệ cuối cùng bằng ràng buộc toàn vẹn	—

Hai thành phần được gom về một nơi duy nhất, và lý do giống nhau:

- Thành phần quản lý máy trạng thái là nơi **duy nhất** đối trạng thái đơn.
- Thành phần tính giá là nơi **duy nhất** tính tiền. Hai công thức tính tiền song song sẽ lệch nhau ngay lần đầu có khuyến mãi hoặc làm tròn, và bên lệch là bên khách nhìn thấy.

Tầng giao diện không tính tiền. Mọi con số hiển thị đều lấy từ phản hồi của máy chủ, kể cả số tiền giảm khi khách thử mã khuyến mãi. Endpoint kiểm tra mã khuyến mãi gọi lại đúng thành phần tính giá mà lúc tạo đơn sẽ sử dụng.

3.4.2. Cấu trúc gói tầng máy chủ

Mã nguồn tổ chức theo **tính năng**, không theo loại kỹ thuật: mười sáu gói dưới `com.tvh.homestay`, mỗi gói là một vùng nghiệp vụ — `auth`, `user`, `room`, `availability`, `booking`, `payment`, `promotion`, `review`, `cms`, `content`, `admin`, `report`, `storage`, `mail`, `common` và `demo`. Cây gói đầy đủ kèm chú thích từng gói trình bày ở Phụ lục P.

Lý do chọn cách tổ chức này: gom theo loại kỹ thuật khiến một thay đổi nghiệp vụ nhỏ phải sửa tệp ở ba thư mục xa nhau. Gom theo tính năng thì mọi thành phần liên quan tới đặt phòng nằm cạnh nhau.

3.4.3. Cấu trúc tầng giao diện

```
src/app
├── core/          - dịch vụ gọi máy chủ, bộ chặn yêu cầu, bộ bảo vệ
tuyên
├── shared/ui/     - thư viện component tự xây
├── features/
│   ├── landing/  - trang khách: trang chủ, phòng, đặt phòng, tra cứu
│   ├── auth/     - đăng nhập, đăng ký
│   └── admin/    - 11 màn hình quản trị, nạp lười
└── styles/       - token màu, lớp nền
```

3.5. Thiết kế giao diện lập trình ứng dụng

Hệ thống phơi bày **80 thao tác trên 63 đường dẫn**. Con số này đếm từ tài liệu mô tả giao diện của hệ thống **đang chạy**, không lấy từ kế hoạch.

3.5.1. Nguyên tắc phân quyền: mặc định là đóng

Cấu hình bảo mật kết thúc bằng lệnh từ chối mọi yêu cầu chưa khớp quy tắc nào phía trên. Một endpoint mới mà người viết quên khai quyền sẽ **bị từ chối**, chứ không lọt ra công khai. Đây là lựa chọn an toàn khi thất bại thay vì mở khi thất bại.

Một lớp kiểm thử giữ một **ma trận 30 tiền tố đường dẫn** và kiểm hai điều: mọi endpoint đã đăng ký phải nằm trong ma trận, và **cấm** khai một dòng bao trùm toàn bộ khu quản trị. Việc liệt kê từng nhóm buộc người thêm endpoint mới phải cân nhắc quyền của nó, thay vì được che miễn phí.

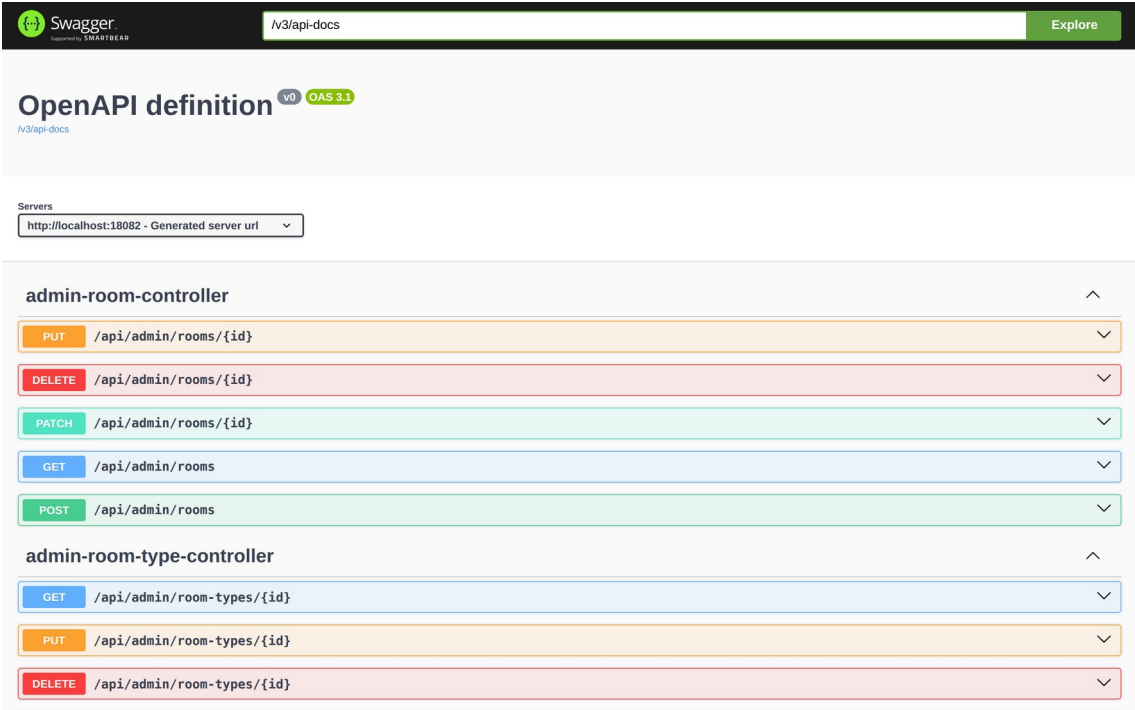
Khu quản trị còn một lớp nữa: bộ lọc trả về lỗi `PASSWORD_CHANGE_REQUIRED` cho mọi đường dẫn trừ ba đường tối thiểu, khi tài khoản còn chờ buộc đổi mật khẩu.

3.5.2. Bảng endpoint theo nhóm

Nhóm	Quyền	Ví dụ
Công khai — tra cứu và nội dung	Không cần đăng nhập	GET /api/room-types, GET /api/availability
Công khai — đơn đặt phòng	Mã đơn và số điện thoại, hoặc mã truy cập	POST /api/bookings, POST /api/bookings/lookup
Xác thực	Hỗn hợp	POST /api/auth/login, GET /api/me
Quản trị — đơn và thanh toán	ADMIN	GET /api/admin/bookings, GET /api/admin/payments
Quản trị — danh mục	ADMIN	POST /api/admin/rooms/{id}/closures
Quản trị — nội dung và đánh giá	ADMIN	PUT /api/admin/content/sections/{key}
Quản trị — báo cáo	ADMIN	GET /api/admin/dashboard
Chỉ có ở cấu hình trình diễn	—	Tài liệu giao diện tương tác

Bảng đầy đủ 80 thao tác nằm ở Phụ lục C.

Hình 3.10 thể hiện giao diện tài liệu tương tác của hệ thống đang chạy.



Hình 3.10 — Giao diện tài liệu tương tác của hệ thống đang chạy (Nguồn: tác giả)

3.5.3. Giới hạn tần suất

Hệ thống giới hạn tần suất theo **chín khoá** khác nhau, chia ba nhóm: theo địa chỉ mạng (ip:auth, ip:availability, ip:promo, ip:booking-create, ip:lookup, ip:cancel), theo danh tính người dùng (email:login, phone:booking) và theo mã đơn (code:lookup). Hạn mức đầy đủ của từng khoá trình bày ở Phụ lục Q.

Điểm thiết kế: khi hai khoá cùng áp cho một yêu cầu, **khoá chặt hơn chặn trước**. Đăng nhập sai liên tục cùng một thư điện tử bị chặn ở lần thứ sáu, còn đổi thư điện tử mỗi lần thì bị chặn ở lần thứ mười một — hai lớp bổ sung cho nhau, một lớp chặn dò mật khẩu một tài khoản, lớp kia chặn quét nhiều tài khoản.

3.5.4. Thiết kế mã lỗi

Phản hồi lỗi theo chuẩn RFC 7807 [4] kèm trường code tự thêm. Tầng giao diện đọc trường code, không đọc câu chữ mô tả, nên việc sửa câu chữ ở tầng máy chủ không làm hỏng màn hình. Hệ thống định nghĩa 15 mã lỗi nghiệp vụ, trong đó các mã quan trọng nhất là ROOM_NOT_AVAILABLE (409) khi phòng vừa được đặt hết, CLOSURE_OVERLAP (409) khi khoảng đóng phòng chồng lấn, và INVALID_STATE_TRANSITION (409) khi bước chuyển trạng thái không hợp lệ. Bảng đầy đủ 15 mã lỗi trình bày ở Phụ lục J.

3.6. Thiết kế giao diện người dùng

Bảng màu là **định nghĩa thương hiệu** của hệ thống. Mọi mã màu tập trung ở một tệp token duy nhất, và một script chạy trong quy trình kiểm tra chặn mọi mã màu viết trực tiếp ở nơi khác. Hai lớp bảo vệ bổ sung cho nhau: xoá bảng màu mặc định của thư viện định kiểu chặn được các lớp tiện ích màu sẵn có, còn script kiểm tra bắt trường hợp viết mã màu thẳng vào thuộc tính kiểu nội tuyến.

Sáu quy ước tương tác bắt buộc, bám theo hướng dẫn khả năng tiếp cận mức A và AA [13]:

Quy ước	Lý do
Vùng chạm tối thiểu 44×44 điểm ảnh trên di động	Ngón tay không chính xác như con trỏ chuột
Chữ không nhỏ hơn 16 điểm ảnh trên di động	Dưới mức này một số trình duyệt tự phóng to khi chạm ô nhập
Lỗi không bao giờ chỉ báo bằng màu	Người khó phân biệt màu không nhận ra; luôn kèm biểu tượng và chữ

Quy ước	Lý do
Viễn chỉ báo tiêu điểm không bao giờ bị xoá	Người dùng bàn phím cần biết đang ở vị trí nào
Tôn trọng tùy chọn giám chuyển động của hệ điều hành	Phục vụ người nhạy cảm với chuyển động
Chặn sẵn thay vì báo lỗi sau	Ngày hết phòng bị chặn ngay trong lịch

Về điều hướng, hệ thống chia ba khu: khu công khai không cần đăng nhập; khu tài khoản khách được bộ bảo vệ tuyến canh; và khu quản trị gồm mười một màn hình, được bộ bảo vệ tuyến canh ở tầng giao diện và kiểm tra vai trò ở tầng máy chủ. Khu quản trị nạp lười theo tuyến để người truy cập trang đặt phòng không phải tải mã của những màn hình không sử dụng.

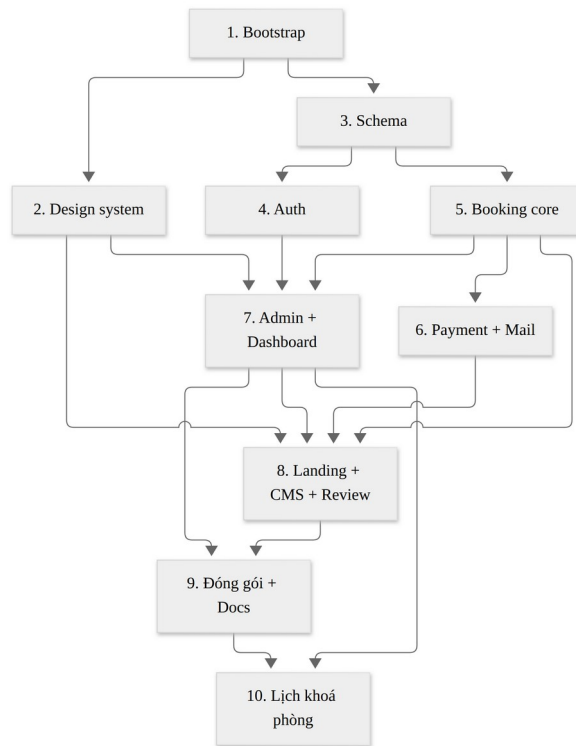
3.7. Môi trường và quy trình phát triển

Hệ thống phát triển bằng IntelliJ IDEA và Visual Studio Code, quản lý phụ thuộc bằng Maven và npm, quản lý mã nguồn bằng Git trên GitHub, cơ sở dữ liệu cục bộ chạy trong container.

Yêu cầu tối thiểu để chạy hệ thống: Docker có Compose phiên bản 2 cho đường chạy khuyến nghị; hoặc JDK 21, Node.js 20.19 trở lên và **PostgreSQL 16** nếu chạy thủ công. PostgreSQL 16 là điều kiện cứng vì hệ thống cần phần mở rộng `btree_gist`.

Đề tài thực hiện theo **mười giai đoạn** tuần tự, tổng khối lượng khoảng 97 giờ công: khởi tạo dự án (5h), hệ thống thiết kế (12h), lược đồ cơ sở dữ liệu (8h), xác thực và phân quyền (7h), lỗi đặt phòng và chống trùng lịch (11h), thanh toán và webhook (10h), khu quản trị (14h), trang khách và quản lý nội dung (16h), đóng gói và tài liệu (7h), lịch khoá phòng theo khoảng ngày (7h). Mỗi giai đoạn có tiêu chí nghiệm thu riêng và chỉ được đóng khi mọi tiêu chí kiểm chứng được bằng lệnh.

Hình 3.11 thể hiện sơ đồ phụ thuộc giữa các giai đoạn, trong đó hai cặp giai đoạn thực hiện song song được vì không dùng chung tệp nào.



Hình 3.11 — Sơ đồ phụ thuộc giữa các giai đoạn (Nguồn: tác giả)

Quy mô mã nguồn tại thời điểm hoàn thành: 174 tệp Java với 15 644 dòng, 100 tệp TypeScript với 12 737 dòng, 8 migration cơ sở dữ liệu, 18 lớp kiểm thử với 129 ca, 31 commit trải từ 07/09/2026 tới 20/09/2026.

3.8. Cài đặt các chức năng chính

3.8.1. Chức năng tìm phòng trống

Đây là chức năng có yêu cầu kỹ thuật cao nhất ở tầng truy vấn. Hệ thống có **bốn truy vấn phòng trống** phục vụ bốn màn hình khác nhau, tất cả đặt trong một lớp truy cập dữ liệu duy nhất:

Truy vấn	Phục vụ	Hậu quả nếu sai
Đếm phòng trống theo loại	Trang danh sách phòng, bước hai của luồng đặt phòng	Khách thấy sai số phòng còn lại
Chọn phòng vật lý để gán	Lúc tạo đơn	Gán nhầm phòng — lỗi im lặng, chỉ lộ ra khi khách tới nhận phòng
Lịch từng đêm toàn homestay	Thanh tìm phòng ở trang chủ	Lịch chặn sai ngày
Lịch từng đêm một loại phòng	Trang chi tiết phòng	Lịch chặn sai ngày

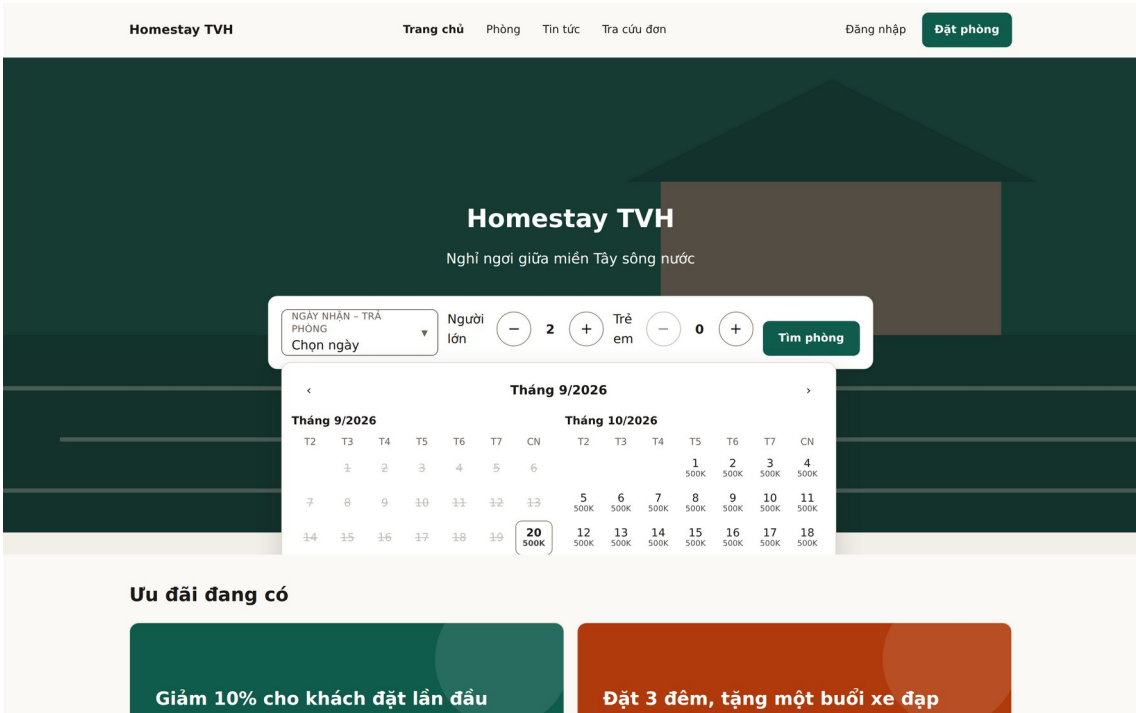
Điểm kỹ thuật thứ nhất: đếm trực tiếp thay vì lấy tổng trừ đi. Truy vấn đếm phòng trống đếm trực tiếp số phòng vừa khả dụng vừa rảnh.

Cách lấy tổng trừ đi số đã đặt sai ở chỗ nó trừ mọi đơn đang giữ chỗ của loại phòng đó, kể cả đơn nằm trên phòng đã chuyển sang bảo trì. Một phòng bảo trì đang có đơn cũ bị trừ **hai lần**: một lần vì nó không còn khả dụng, một lần nữa vì nó vẫn có đơn. Website báo thiếu phòng và mất doanh thu mà không có dấu hiệu nào.

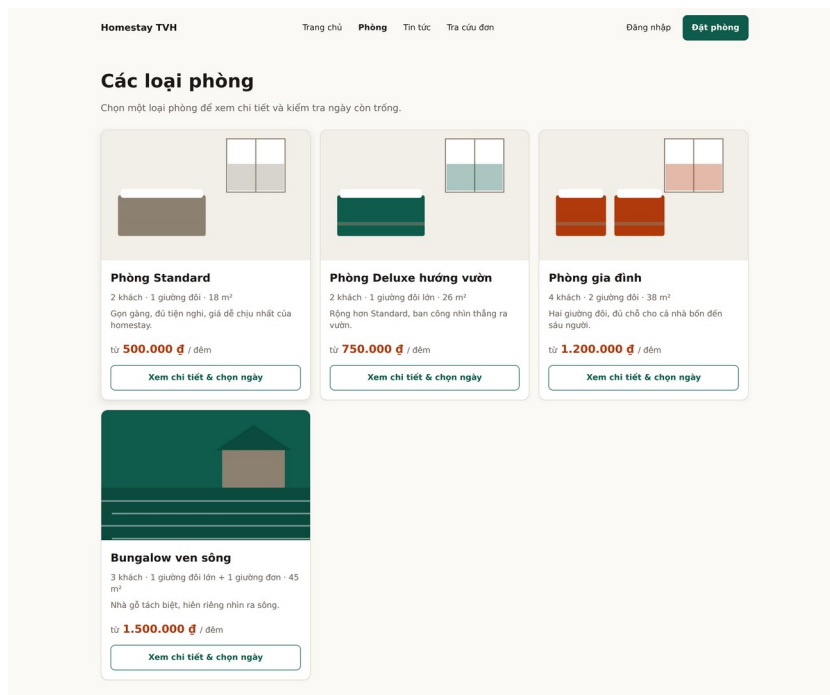
Điểm kỹ thuật thứ hai: gộp cả khoảng ngày vào một câu lệnh. Truy vấn lịch toàn homestay dùng hàm sinh chuỗi ngày của PostgreSQL để trả về mọi đêm trong một lần gọi, thay vì lặp từng đêm. Khoảng tối đa là 120 ngày, và 120 lượt đi về cơ sở dữ liệu cho một lần mở lịch đủ để người dùng cảm nhận được độ trễ.

Điểm kỹ thuật thứ ba: vị trí của điều kiện lọc trong phép nối trái. Truy vấn lịch toàn homestay dùng phép nối trái để bảo đảm mọi đêm đều xuất hiện trong kết quả, kể cả đêm không còn phòng nào. Điều kiện lọc khoảng đóng phòng phải nằm trong mệnh đề điều kiện nối, không phải mệnh đề lọc. Đặt sai chỗ sẽ biến phép nối trái thành phép nối trong, và những đêm hết phòng biến mất khỏi kết quả thay vì trả về số không — trong khi tăng giao diện hiển ngày vắng mặt là ngày không bị chặn.

Hình 3.12 thể hiện trang chủ với thanh tìm phòng và lịch chọn ngày đang mở, trong đó các ngày đã kín phòng bị chặn sẵn. Hình 3.13 thể hiện kết quả tìm phòng với nhãn số phòng còn lại và tổng tiền cả kỳ.



Hình 3.12 — Trang chủ với thanh tìm phòng và lịch chọn ngày đang mở, trong (Nguồn: tác giả)



Hình 3.13 (Nguồn: tác giả)

3.8.2. Chức năng đặt phòng và vòng thử gán phòng

Thuật toán gán phòng là nơi lý thuyết trình bày ở Chương 2 được hiện thực hoá:

Với mỗi phòng ứng viên còn rảnh:

Mở một giao dịch MỚI

Thư'ghi dòng gán phòng

Nếu cơ sở dữ liệu trả về `SQLSTATE 23P01`:

→ một khách khác vừa chiếm mất phòng này

→ huỷ giao dịch, thư'phòng tiếp theo

Nếu thành công:

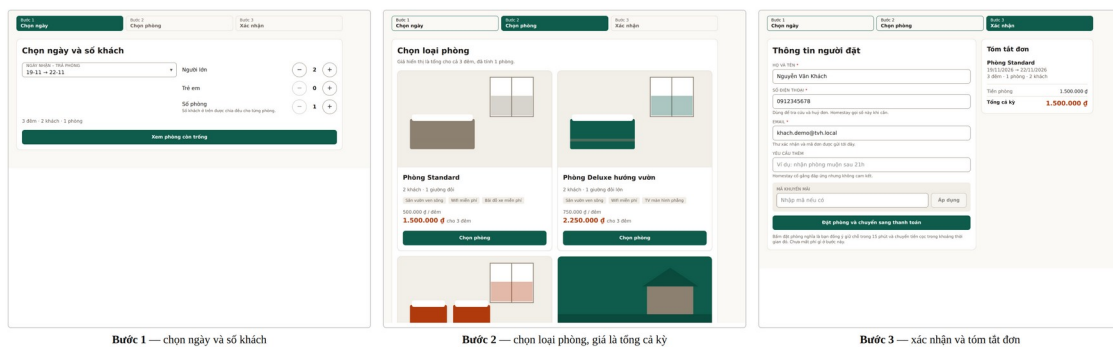
→ xác nhận giao dịch và kết thúc

Hết phòng đề'thư' → trả về' lỗi ROOM_NOT_AVAILABLE mã 409

Dòng "mở một giao dịch mới" không phải tuỳ chọn. Khi PostgreSQL bác một câu lệnh vì vi phạm ràng buộc, toàn bộ giao dịch bị đánh dấu hỏng; mọi câu lệnh tiếp theo trong cùng giao dịch đó trả về mã 25P02 chứ không thực thi. Việc thử phòng tiếp theo trong cùng giao dịch là **không thể thành công**.

Hệ thống cũng chỉ bắt **đúng** mã 23P01. Bắt chung mọi lỗi toàn vẹn dữ liệu sẽ khiến một lỗi khoá ngoại — tức là lỗi lập trình thật — bị báo cho khách thành hết phòng, và lỗi đó không bao giờ được phát hiện.

Hình 3.14 thể hiện ba bước của luồng đặt phòng.

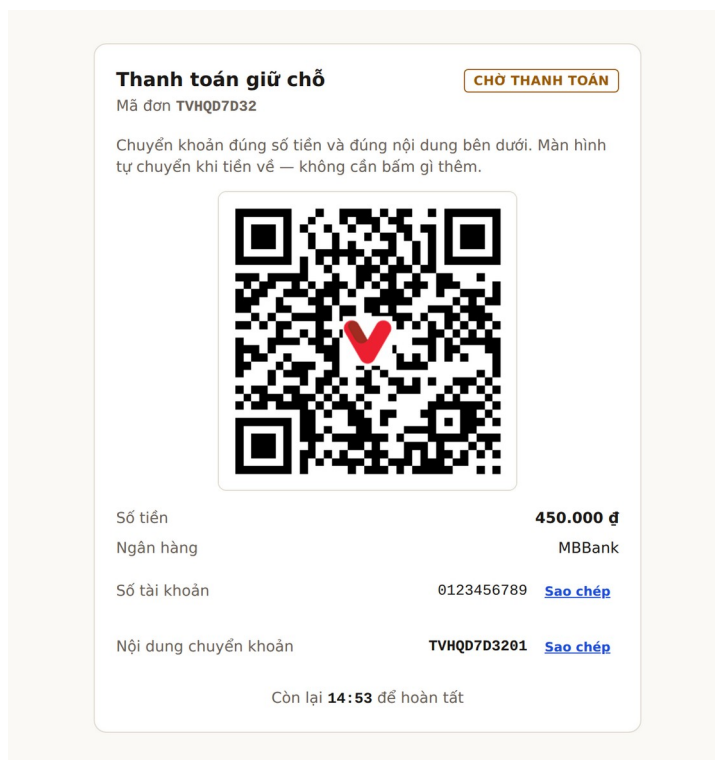


Hình 3.14 — Ba bước của luồng đặt phòng (Nguồn: tác giả)

3.8.3. Chức năng thanh toán

Hệ thống sinh mã QR theo chuẩn VietQR, nội dung chuyển khoản là **mã đơn ghép hai chữ số thứ tự lần thử** để phân biệt các lần chuyển khoản của cùng một đơn. Đồng hồ đếm ngược 15 phút trên màn hình ứng với hạn giữ chỗ **có thật** trong cơ sở dữ liệu, không phải đồng hồ trang trí.

Hình 3.15 thể hiện màn hình thanh toán.



Hình 3.15 — Màn hình thanh toán (Nguồn: tác giả)

Xử lý webhook theo bảng quyết định sau:

Tình huống	Xử lý
Đủ tiền cọc	Chuyển sang CONFIRMED, gửi thư xác nhận
Thiếu tiền	Chuyển sang AWAITING_REVIEW, đánh dấu cần đối soát

Tình huống	Xử lý
Thừa tiền	Đánh dấu cần hoàn lại phần thừa
Webhook gửi lại lần hai	Bỏ qua, không cộng tiền hai lần
Không khớp đơn nào	Vẫn ghi vào nhật ký webhook để người đối soát xử lý
Tiền về sau khi đơn đã đóng	Mở lại sang AWAITING_REVIEW, thử giành lại phòng

Nguyên tắc thiết kế xuyên suốt: không nhánh nào để tiền của khách biến mất im lặng. Mọi khoản tiền không xử lý tự động được đều vào hàng đợi đối soát thủ công, chứ không bị bỏ qua.

3.8.4. Chức năng quản lý ngày khả dụng

Trước giai đoạn mười, phòng chỉ có công tắc trạng thái vận hành, và công tắc đó **không gắn với ngày**: muốn ghi nhận một phòng sơn lại trong năm ngày thì phải tự nhớ tắt rồi tự nhớ bật, mà ngày quên bật là ngày mất doanh thu không dấu vết.

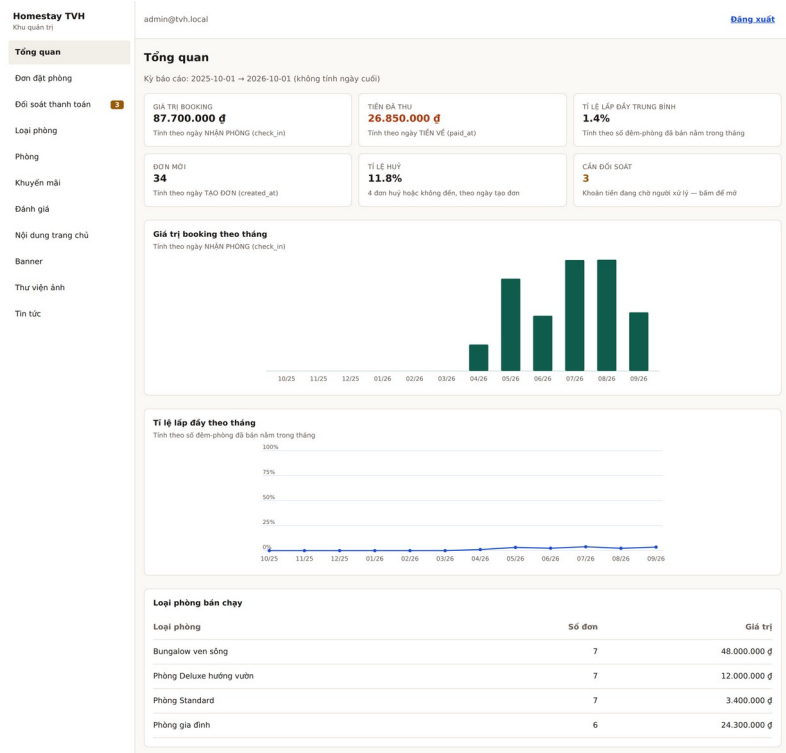
Giải pháp gồm ba phần: bảng `room_closures` với cột sinh tự động dùng cùng quy ước nửa mở, ràng buộc loại trừ chống chồng lấn, và một điều kiện lọc thêm vào **cả bốn** truy vấn phòng trống.

Phần thưởng kiến trúc: tăng giao diện phía khách **không phải sửa một dòng mã nào**. Cả bốn màn hình khách đều đọc phòng trống qua bốn truy vấn đó, nên sửa ở tầng dữ liệu làm cả bốn tự đúng theo — kết quả của việc gom mọi truy vấn phòng trống vào một lớp duy nhất từ giai đoạn năm.

3.8.5. Khu quản trị

Khu quản trị gồm **mười một màn hình**, nạp lười theo tuyến.

Hình 3.16 thể hiện trang tổng quan với biểu đồ doanh thu theo tháng, tỉ lệ lấp đầy và tỉ lệ huỷ. Hình 3.17 thể hiện màn hình đối soát thanh toán với các khoản thiếu tiền và thừa tiền. Hình 3.18 thể hiện danh sách đơn đặt phòng kèm bộ lọc theo trạng thái. Hình 3.19 thể hiện chi tiết một đơn: dòng thời gian trạng thái, các lần thanh toán, hộp thư đi và ghi chú nội bộ — bốn thứ mà chủ homestay cần xem cùng lúc khi có việc phải xử lý.



Hình 3.16 — Trang tổng quan với biểu đồ doanh thu theo tháng, tỉ lệ lấp (Nguồn: tác giả)

Homestay TVH admin@tvh.local Đăng xuất

Đối soát thanh toán

TRANG THÁI ĐỐI SOÁT

Tất cả khoản cần xử lý

Áp dụng

TVHDEMO032 · Lê Minh Châu CÁN XEM XÉT

Nội dung chuyển khoản: TVHDEMO03201
Đã nhận 75.000 đ / cần 150.000 đ · đơn đang AWAITING_REVIEW

GHI CHÚ ĐỐI SOÁT

Đánh dấu đã xử lý Xác nhận đơn thủ công

TVHDEMO002 · Trần Văn Bình CÁN XEM XÉT

Nội dung chuyển khoản: TVHDEMO00201
Đã nhận 648.000 đ / cần 1.080.000 đ · đơn đang CHECKED_OUT

GHI CHÚ ĐỐI SOÁT

Đánh dấu đã xử lý Xác nhận đơn thủ công

TVHDEMO001 · Nguyễn Thị An CÁN HOÀN TIẾN

Nội dung chuyển khoản: TVHDEMO00101
Đã nhận 540.000 đ / cần 450.000 đ · đơn đang CHECKED_OUT

GHI CHÚ ĐỐI SOÁT

Đánh dấu đã xử lý Xác nhận đơn thủ công

Hình 3.17 (Nguồn: tác giả)

Homestay TVH

Khu quản trị

Tổng quan

Đơn đặt phòng

Đối soát thanh toán

Loại phòng

Phòng

Khuyến mãi

Đánh giá

Nội dung trang chủ

Banner

Thư viện ảnh

Tin tức

admin@tvh.local

Đăng xuất

Đơn đặt phòng

TRANG THÁI

Tất cả

NHÂN PHÒNG TỪ

2026-01-01

NHÂN PHÒNG ĐẾN

2026-12-31

TÌM MÃ / TÊN / SỐ

Xuất CSV

Áp dụng

Mã đơn	Khách	Loại phòng	Lưu trú	Số phòng	Tổng tiền	Trạng thái
TVHDEM0040	Nguyễn Thị An - 0910001480	Phòng Standard	2026-11-04 → 2026-11-05	1	500.000 đ	Đã xác nhận
TVHDEM0039	Huỳnh Ngọc Oanh - 0910001443	Bungalow ven sông	2026-10-30 → 2026-11-03	1	6.000.000 đ	Chờ thanh toán
TVHDEM0038	Dương Văn Nam - 0910001406	Phòng gia đình	2026-10-25 → 2026-10-28	1	3.600.000 đ	Đã xác nhận
TVHDEM0037	Trần Văn Bình - 0905333444	Phòng Deluxe hướng vườn	2026-10-20 → 2026-10-22	1	1.500.000 đ	Đã xác nhận
TVHDEM0036	Nguyễn Thị An - 0905111222	Phòng Standard	2026-10-15 → 2026-10-16	2	900.000 đ	Chờ thanh toán
TVHDEM0035	Đặng Thu Hà - 0910001295	Bungalow ven sông	2026-10-10 → 2026-10-14	1	6.000.000 đ	Đã xác nhận
TVHDEM0034	Võ Quốc Đạt - 0910001258	Phòng gia đình	2026-10-05 → 2026-10-08	1	3.600.000 đ	Hết hạn giữ chỗ
TVHDEM0033	Phạm Hồng Duyên - 0910001221	Phòng Deluxe hướng vườn	2026-09-30 → 2026-10-02	1	1.500.000 đ	Chờ thanh toán
TVHDEM0032	Lê Minh Châu - 0910001184	Phòng Standard	2026-09-25 → 2026-09-26	1	500.000 đ	Chờ đối soát
TVHDEM0031	Trần Văn Bình - 0910001147	Bungalow ven sông	2026-09-20 → 2026-09-24	1	6.000.000 đ	Đã nhận phòng
TVHDEM0030	Trần Văn Bình - 0905333444	Phòng gia đình	2026-09-15 → 2026-09-18	1	3.300.000 đ	Đã trả phòng
TVHDEM0029	Nguyễn Thị An - 0905111222	Phòng Deluxe hướng vườn	2026-09-10 → 2026-09-12	1	1.500.000 đ	Đã trả phòng
TVHDEM0028	Dương Văn Nam - 0910001036	Phòng Standard	2026-09-05 → 2026-09-06	1	500.000 đ	Đã trả phòng
TVHDEM0027	Ngô Kim Lan - 0910000999	Bungalow ven sông	2026-08-31 → 2026-09-04	2	12.000.000 đ	Đã trả phòng
TVHDEM0026	Bùi Thanh Hải - 0910000962	Phòng gia đình	2026-08-26 → 2026-08-29	1	3.600.000 đ	Không đến
TVHDEM0025	Đặng Thu Hà - 0910000925	Phòng Deluxe hướng vườn	2026-08-21 → 2026-08-23	1	1.500.000 đ	Đã trả phòng
TVHDEM0024	Võ Quốc Đạt - 0910000888	Phòng Standard	2026-08-16 → 2026-08-17	1	450.000 đ	Đã trả phòng
TVHDEM0023	Trần Văn Bình - 0905333444	Bungalow ven sông	2026-08-11 → 2026-08-15	1	6.000.000 đ	Đã trả phòng
TVHDEM0022	Nguyễn Thị An - 0905111222	Phòng gia đình	2026-08-06 → 2026-08-09	1	3.600.000 đ	Đã hủy
TVHDEM0021	Trần Văn Bình - 0910000777	Phòng Deluxe hướng vườn	2026-08-01 → 2026-08-03	1	1.500.000 đ	Đã trả phòng

1

2

Bấm vào mã đơn để mở chi tiết: [Mã đơn: TVHDEM0040](#)

Hình 3.18 (Nguồn: tác giả)

Homestay TVH

Khu quản trị

Tổng quan

Đơn đặt phòng

Đối soát thanh toán

Loại phòng

Phòng

Khuyến mãi

Đánh giá

Nội dung trang chủ

Banner

Thư viện ảnh

Tin tức

admin@tvh.local

Đăng xuất

[← Về danh sách đơn](#)

TVHDEM0040

ĐÃ XÁC NHẬN

Thanh toán: DEPOSIT_PAID

Thông tin khách

Họ tên

Điện thoại

Email

Lưu trú

Khách

Nguyễn Thị An

0910001480

khach40@example.com

2026-11-04 → 2026-11-05 (1 đêm)

2 người lớn, 1 trẻ em

Đồng thời gian trạng thái

Tạo đơn → PENDING_PAYMENT

2026-10-28T00:00:00+07:00 - GUEST

Đơn mẫu

PENDING_PAYMENT → CONFIRMED

2026-10-29T00:00:00+07:00 - SYSTEM

Đơn mẫu

Tiến và phòng

Tổng tiền

Tiến cọc

Giảm giá

Phòng được gán

Phòng 104 · tầng 1 · AVAILABLE

500.000 đ

150.000 đ

0 đ

Thanh toán và thư

Lần 1 · TVHDEM004001

Đã nhận 150.000 / 150.000 đ - SUCCEEDED - đối soát NONE

Hộp thư đi

Chưa có thư nào được xếp hàng cho đơn này.

Thao tác

CHUYỂN SANG

CHỌN TRẠNG THÁI

Chọn trạng thái

GHI CHÚ (ĐI VÀO NHẤT KỲ)

Thực hiện

Ghi chú nội bộ

Chưa có ghi chú nào.

THÊM GHI CHÚ

Lưu ghi chú

Hình 3.19 (Nguồn: tác giả)

3.8.6. Quản lý nội dung và lọc HTML

Khu quản trị cho phép soạn nội dung HTML cho trang chủ và tin tức. Đây là một bề mặt tấn công chèn mã kịch bản cổ điển [6].

Hệ thống lọc HTML **ở tầng vào**, trước khi lưu, bằng thư viện lọc của OWASP với **danh sách thẻ cho phép tường minh** — không phải danh sách thẻ cấm. Lý do: danh sách cấm luôn thiếu; mỗi khi xuất hiện một thẻ hoặc thuộc tính nguy hiểm mới thì danh sách cấm lại lỗi thời, còn danh sách cho phép vẫn đúng.

Với nội dung do **khách** nhập, ví dụ đánh giá, hệ thống không lọc HTML mà hiển thị dưới dạng văn bản thuần, vì khách không có nhu cầu định dạng.

3.9. Cài đặt mô hình bảo mật

3.9.1. Xác thực và buộc đổi mật khẩu tạm

Tài khoản quản trị của bản trình diễn được sinh với **mật khẩu ngẫu nhiên, chỉ in một lần vào nhật ký container**, không ghi vào bất kỳ tệp nào trong mã nguồn.

Tài khoản đó mang cờ buộc đổi mật khẩu. Một bộ lọc chặn **mọi** đường dẫn trừ ba đường tối thiểu — xem thông tin bản thân, đổi mật khẩu, đăng xuất — cho tới khi mật khẩu được đổi. Lý do: mật khẩu tạm đã đi qua nhật ký nên **không còn là bí mật**.

3.9.2. Phân biệt mã đơn và mã truy cập

Một quyết định bảo mật tinh tế: hệ thống dùng **hai mã khác nhau** cho một đơn.

Mã đơn xuất hiện trên sao kê ngân hàng vì nó nằm trong nội dung chuyển khoản. Nghĩa là bất kỳ ai nhìn thấy sao kê đều biết mã đơn của người khác.

Mã truy cập là bí mật thao tác, chỉ có trong liên kết ở thư xác nhận.

Vì thế endpoint xem trạng thái thanh toán **bắt buộc** mã truy cập: nếu chỉ cần mã đơn là xem được, ai thấy sao kê cũng theo dõi được đơn của người khác.

3.9.3. Giới hạn tần suất sau máy chủ web

Ứng dụng nằm sau máy chủ web, nên mọi yêu cầu đến đều mang địa chỉ mạng của container máy chủ web. Giới hạn theo địa chỉ đó là giới hạn **toàn bộ người dùng chung một hạn mức**.

Giải pháp là để máy chủ web **ghi đè** trường tiêu đề chứa địa chỉ thật của người gọi. Nhưng trường này do phía khách gửi lên nên **giả mạo được**, trừ khi hai điều kiện cùng thoả mãn:

1. Máy chủ web **ghi đè** trường đó chứ không nối thêm vào giá trị có sẵn [3].
2. Cổng của ứng dụng **không mở ra ngoài**, nên không ai gọi thẳng vào được.

Hai điều kiện này phải đi cùng nhau; thiếu một là lớp giới hạn tần suất trở thành hình thức.

3.9.4. Quản lý bí mật

Hai biến bí mật của hệ thống **không có giá trị mặc định ở bất kỳ đâu**: không trong tệp cấu hình, không trong tệp biến môi trường mẫu, không trong tệp đóng gói. Ứng dụng **dừng khởi động** khi thiếu, ở mọi cấu hình.

Lý do: kho mã nguồn này công khai. Một giá trị mặc định được cho là an toàn cho bản trình diễn nằm trong kho đồng nghĩa với việc bất kỳ ai sao chép về cũng **tự ký được token vai trò quản trị** cho mọi bản triển khai dùng kho này.

Một script riêng là đường **duy nhất** tạo ra các giá trị thật, sinh ngẫu nhiên vào tệp biến môi trường với quyền truy cập hạn chế.

3.9.5. Các lớp bảo vệ khác

Lớp	Biện pháp
Tiêu đề bảo mật	Chính sách bảo mật nội dung, chống nhúng khung, chống đoán kiểu tệp
Ảnh tải lên	Kiểm định dạng, giới hạn dung lượng, giải mã lại và đổi tên thành định danh ngẫu nhiên
Xuất tệp CSV	Thoát ký tự đầu dòng để chống chèn công thức bảng tính [5]
Mật khẩu	Băm bằng thuật toán bcrypt

3.10. Đóng gói và triển khai

3.10.1. Kiến trúc đóng gói

Bốn dịch vụ:

Dịch vụ	Ảnh nền	Cổng mở ra máy chủ
Máy chủ web	nginx:alpine	80
Ứng dụng	eclipse-temurin:21-jre-alpine	Không
Cơ sở dữ liệu	postgres:16	Không
Máy chủ thư giả lập	mailpit	8025

Việc ứng dụng và cơ sở dữ liệu không mở cổng là một quyết định bảo mật, không phải tối giản cấu hình — đó là điều kiện để tin được thông tin địa chỉ mà máy chủ web chuyển tiếp, như đã trình bày ở mục 3.9.3.

Ảnh ứng dụng chạy bằng **người dùng không có quyền quản trị**, và được dựng bằng tệp Dockerfile nhiều tầng nên ảnh cuối không chứa công cụ biên dịch.

3.10.2. Cấu hình máy chủ web

Máy chủ web phải chuyển tiếp **bốn nhóm đường dẫn** chứ không chỉ nhóm giao diện lập trình ứng dụng:

Đường dẫn	Hậu quả nếu quên chuyển tiếp
/api/**	Toàn bộ hệ thống không hoạt động
/swagger-ui/**	Trả về trang ứng dụng kèm mã 200 — trông giống như thành công
/v3/api-docs/**	Tương tự
/uploads/**	Mọi ảnh tải lên trả về lỗi 404

Cả bốn khối phải dùng cú pháp tiền tố ưu tiên. Nguyên nhân: khối cuối tệp xử lý tệp tĩnh là một khối biểu thức chính quy, và máy chủ web cho khối biểu thức chính quy thắng mọi khối tiền tố thường [3]. Không có tiền tố ưu tiên thì ảnh tải lên rơi vào khối tĩnh và trả về lỗi.

3.10.3. Hai cấu hình chạy

Hệ thống chỉ có **hai** cấu hình, cố ý không nhiều hơn:

Cấu hình	Sử dụng khi	Bao gồm
Trình diễn	Phát triển và bản đem bảo vệ	Dữ liệu mẫu, tài liệu tương tác, trang thư viện component
Thật	Triển khai thật	Không dữ liệu mẫu, không tài liệu tương tác, không trang thư viện

Việc đổi cấu hình trên cùng một khối dữ liệu là **an toàn** — đây chính là lý do dữ liệu mẫu không nằm trong lịch sử migration.

3.10.4. Dữ liệu mẫu

Cấu hình trình diễn nạp sẵn: 4 loại phòng, 15 phòng vật lý, 12 tiện nghi, **40 đơn đặt phòng trải đủ tám trạng thái**, 3 khoản cần đối soát, 3 mã khuyến mãi với ba tình trạng khác nhau, 8 đánh giá, 1 khoảng đóng phòng, và nội dung trang chủ đầy đủ.

Mọi ngày trong dữ liệu mẫu là tương đối so với ngày hiện tại, nên bộ dữ liệu không cũ đi theo thời gian: ngày bảo vệ vẫn có đơn trong tương lai để trình diễn.

3.10.5. Xử lý múi giờ

Toàn hệ thống chạy theo múi giờ Việt Nam, đặt ở **bốn tầng độc lập**: biến môi trường của container, tham số máy ảo Java, cấu hình chuyển đổi dữ liệu sang JSON, và cấu hình kết nối cơ sở dữ liệu.

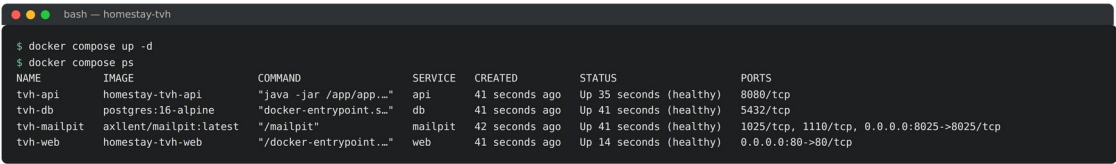
Chỉ đặt cấu hình chuyển đổi JSON là **không đủ** — thuộc tính đó chỉ chi phối cách dữ liệu được biểu diễn khi trả về, không đổi múi giờ mặc định của máy ảo. Hệ quả nếu làm sai: đơn tạo trong khung nửa đêm tới rạng sáng giờ Việt Nam bị gom nhóm vào **tháng trước** ở trang tổng quan, trong khi đồng hồ đếm ngược trên màn hình thanh toán vẫn đúng — sai một phần nên rất khó nghi ngờ.

Endpoint kiểm tra tình trạng hệ thống phơi bày cả múi giờ ứng dụng lẫn múi giờ mặc định của máy ảo để kiểm tra được điều này trực tiếp.

3.10.6. Quy trình triển khai ba lệnh

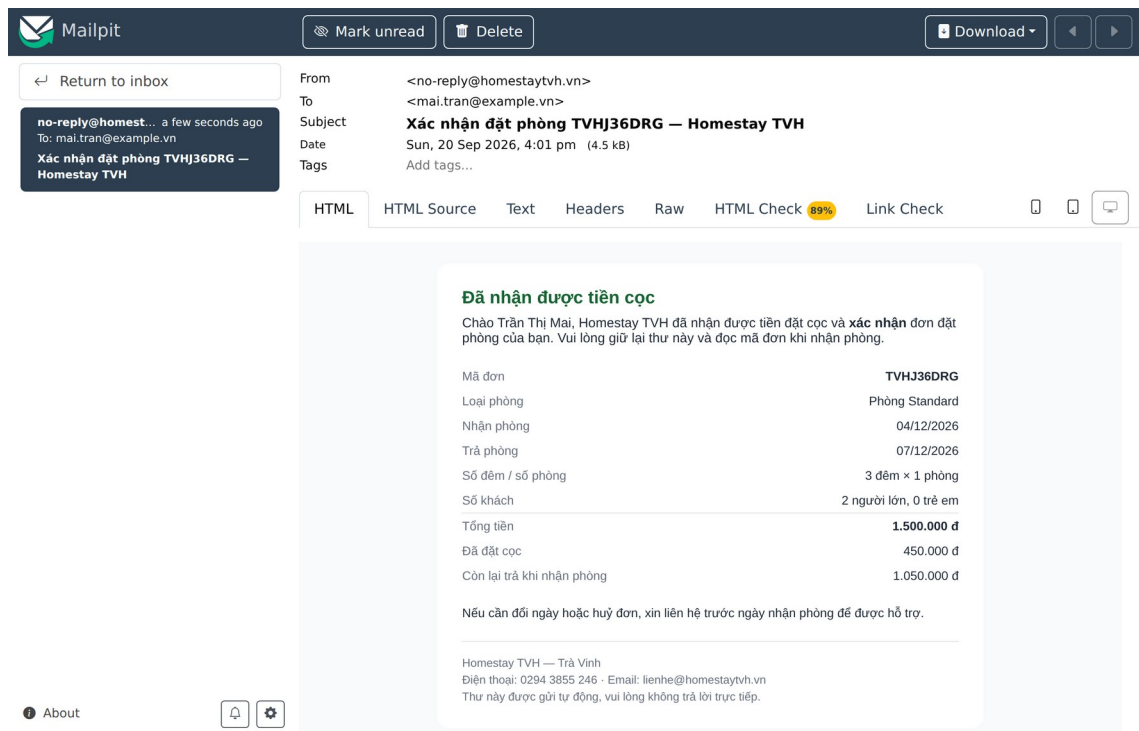
```
git clone <địa-chỉ-kho> homestay-tvh && cd homestay-tvh
./scripts/init-env.sh          # sinh bí mật ngẫu nhiên
docker compose up -d --build  # dựng và chạy 4 dịch vụ
```

Hình 3.20 thể hiện trạng thái bốn dịch vụ sau khi khởi động, và Hình 3.21 thể hiện hộp thư giả lập với thư xác nhận đã gửi.



NAME	IMAGE	COMMAND	SERVICE	CREATED	STATUS	PORTS
tvh-api	homestay-tvh-api	"java -jar /app/app..."	api	41 seconds ago	Up 35 seconds (healthy)	8080/tcp
tvh-db	postgres:16-alpine	"docker-entrypoint.s..."	db	41 seconds ago	Up 41 seconds (healthy)	5432/tcp
tvh-mailpit	axllent/mailpit:latest	"/mailpit"	mailpit	42 seconds ago	Up 41 seconds (healthy)	1025/tcp, 1110/tcp, 0.0.0.0:8025->8025/tcp
tvh-web	homestay-tvh-web	"/docker-entrypoint..."	web	41 seconds ago	Up 14 seconds (healthy)	0.0.0.0:80->80/tcp

Hình 3.20 — Trạng thái bốn dịch vụ sau khi khởi động (Nguồn: tác giả)



Hình 3.21 (Nguồn: tác giả)

CHƯƠNG 4. KẾT QUẢ NGHIÊN CỨU

Chương này trình bày các kết quả đạt được sau quá trình thực hiện đề án: kết quả kiểm thử, đánh giá hiệu năng và khả năng tiếp cận, đối chiếu với mục đích ban đầu, và các giới hạn đã biết của hệ thống.

4.1. Chiến lược kiểm thử

Hệ thống có **129 ca kiểm thử tự động trong 18 lớp**, tất cả đều thành công.

4.1.1. Lý do không sử dụng cơ sở dữ liệu giả lập

Mọi ca kiểm thử tích hợp dựng một **PostgreSQL 16 thật** bằng Testcontainers. Đề tài không giả lập cơ sở dữ liệu, vì phần lớn nội dung đáng kiểm thử ở hệ thống này **chính là hành vi của cơ sở dữ liệu**: ràng buộc loại trừ, kiểu khoảng, trigger hoãn, mã trạng thái SQL. Giả lập chúng là kiểm thử một thứ không tồn tại.

Container được dùng chung cho mọi lớp kiểm thử kế thừa cùng lớp nền, khởi động một lần cho cả lần chạy. Dựng lại cơ sở dữ liệu cho từng lớp kiểm thử tốn nhiều thời gian hơn phần việc thật.

Hai biến bí mật bắt buộc được **sinh ngẫu nhiên mỗi lần chạy** chứ không ghi sẵn vào tệp cấu hình kiểm thử. Cách này vừa tránh đưa giá trị vào kho mã nguồn công khai, vừa chứng minh luôn rằng ứng dụng thật sự đòi hai biến đó.

4.1.2. Các cấp độ kiểm thử

Cấp độ	Ví dụ lớp	Kiểm điều gì
Kiểm thử đơn vị	Lọc HTML, xuất tệp CSV	Logic thuần, không cần cơ sở dữ liệu
Kiểm thử tích hợp	Phần lớn các lớp	Nhiều tầng cùng cơ sở dữ liệu thật
Kiểm thử tranh chấp	Đặt phòng đa luồng, đua thanh toán	Nhiều luồng chạy song song thật
Kiểm thử lược đồ	Migration, ràng buộc	Chính cấu trúc cơ sở dữ liệu

Dự án không cấu hình pha kiểm thử tích hợp riêng; công cụ chạy kiểm thử được nói để nhận cả lớp có hậu tố chỉ kiểm thử tích hợp, nên lệnh kiểm chứng gồm biên dịch, chạy toàn bộ 129 ca và đóng gói.

4.2. Kết quả kiểm thử tự động

4.2.1. Tổng hợp theo nhóm

Nhóm	Số lớp	Số ca	Trọng tâm
Lược đồ và ràng buộc	3	19	Migration dựng đúng 21 bảng; từng ràng buộc kiểm tra thật sự chặn
Đặt phòng	4	26	Tranh chấp đa luồng, đếm phòng trống, máy trạng thái, quét hết hạn
Ngày khả dụng	1	9	Khoảng đóng phòng trừ đúng ở cả bốn truy vấn
Thanh toán	2	15	Webhook, chống cộng tiền hai lần, cửa sổ tranh chấp
Xác thực và phân quyền	2	10	Vòng đời token, ma trận 30 tiền tố
Nội dung và đánh giá	3	32	Lọc HTML, nội dung công khai, quy tắc đánh giá
Báo cáo và lưu trữ	3	23	Số liệu tổng quan, xuất CSV, tải ảnh
Tổng	18	129	

Bảng chi tiết từng lớp kiểm thử trình bày ở Phụ lục I.

4.2.2. Ba ca kiểm thử trọng tâm

Thứ nhất, kiểm thử tranh chấp đặt phòng. Nhiều luồng thật chạy song song cùng đặt phòng cuối cùng. Kết quả bắt buộc: **đúng một luồng thắng**, không có hai dòng gán phòng chồng lấn trong cơ sở dữ liệu. Đây là bằng chứng trực tiếp cho mục đích số 2 của đề tài.

Thứ hai, kiểm thử phòng đang đóng không bao giờ được gán. Ba trong bốn truy vấn phòng trống chỉ ảnh hưởng thứ khách nhìn thấy; bỏ sót truy vấn chọn phòng vật lý thì **đơn vẫn tạo được và phòng đang sửa chữa vẫn bị gán** — lỗi im lặng, chỉ lộ ra khi khách tới nhận phòng. Ca kiểm thử này canh đúng chỗ đó.

Thứ ba, kiểm thử tiền về muộn. Tiền về **sau khi** đơn đã hết hạn: đơn mở lại sang trạng thái chờ đối soát, hệ thống thử giành lại phòng; không giành được thì vào hàng đợi hoàn tiền. Đây là bằng chứng cho tiêu chí không nhánh nào để tiền biến mất im lặng.

4.3. Các lỗi thực tế phát hiện trong quá trình thực hiện

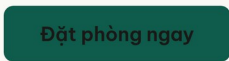
Mười một lỗi dưới đây đều là lỗi **đã xảy ra thật** trong quá trình làm, kèm nguyên nhân gốc chứ không phải triệu chứng.

#	Hiện tượng	Nguyên nhân gốc	Cách khắc phục
1	Giao dịch thử phòng tiếp theo luôn thất bại	Bắt lỗi ràng buộc rồi thử tiếp trong cùng giao dịch ; PostgreSQL đã huỷ giao dịch nên mọi lệnh sau trả 25P02	Mỗi lượt thử chạy trong một giao dịch mới
2	Website báo thiếu phòng so với thực tế	Truy vấn lấy tổng trừ đi số đã đặt trừ hai lần phòng bảo trì đang có đơn	Đếm trực tiếp phòng vừa khả dụng vừa rảnh
3	Giao dịch bị bác khi khách trả phòng	Nhả phòng lúc chuyển sang CHECKED_OUT làm trigger kiểm số phòng bác cả giao dịch	Trạng thái CHECKED_OUT không nhả phòng
4	Toàn bộ trang web hiển thị không có định kiểu	Chính sách bảo mật nội dung chặn thuộc tính sự kiện mà công cụ tối ưu định kiểu tự sinh ra	Tắt tính năng tối ưu đó thay vì nới lỏng chính sách bảo mật
5	Mọi nút bấm chính có độ tương phản khoảng 2:1	Tập định kiểu nền không nằm trong tầng CSS nên thắng mọi lớp tiện ích bất kể độ ưu tiên	Bọc tập nền trong tầng cơ sở
6	Ảnh tải lên trả về lỗi 404	Khối biểu thức chính quy của máy chủ web thắng khối tiện tố thường	Dùng cú pháp tiện tố ưu tiên cho cả bốn khối chuyển tiếp
7	Màn hình thanh toán trắng trơn	Component gọi hàm đọc tham số đầu vào trong hàm khởi tạo , trước khi khung ứng dụng gán tham số	Chuyển sang phương thức chạy sau khi khởi tạo
8	Bộ nạp dữ liệu mẫu cộng dồn mỗi lần khởi động	Điều kiện chống trùng khoá theo ngày tương đối nên mỗi ngày lại khớp khác	Đổi điều kiện sang khoá toàn bảng
9	Khu quản trị đóng nhầm phòng không hiển thị	Khối giao diện giữ định danh phòng cũ sau khi bộ lọc của màn hình cha thay đổi	Đổi chiều định danh với danh sách phòng đang hiển thị
10	Danh sách đơn nói "bấm vào mã đơn để mở chi tiết" nhưng không bấm được	Ô mã đơn là ô bảng thường; chỉ một liên kết ví dụ dưới bảng mở được đơn đầu tiên , mười chín đơn còn lại không có lỗi vào	Thêm kiểu cột liên kết cho bảng dữ liệu dùng chung, mã đơn của mọi hàng thành thẻ liên kết thật
11	Ô chọn tệp ảnh không	Ô ẩn bằng lớp chỉ-đọc-	Bỏ ô khỏi thứ tự Tab

#	Hiện tượng	Nguyên nhân gốc	Cách khắc phục
	có tên cho trình đọc màn hình	màn-hình nhưng vẫn nằm trong thứ tự Tab , thành một điểm dừng không tên	và đặt nhãn cho nó; nút bấm nhìn thấy được mới là lỗi vào

Về lỗi số 4 và số 5: cả hai chỉ phát hiện được khi **chụp màn hình bằng trình duyệt thật**. Việc biên dịch thành công không nói gì về việc trang có hiển thị đúng hay không. Hình 4.3 so sánh trước và sau khi khắc phục lỗi tương phản.

Độ tương phản của nút chính trước và sau khi bọc tệp nền vào tầng CSS

Trước — quy tắc button { color: inherit } nằm ngoài tầng  Chữ #1C1917 trên nền #0F5C4C Tỉ lệ tương phản 2,21 : 1 — dưới ngưỡng 4,5 : 1 của WCAG AA	Sau — tệp nền được bọc trong @layer base  Chữ #FFFFFF trên nền #0F5C4C Tỉ lệ tương phản 7,91 : 1 — vượt cả ngưỡng 7 : 1 của mức AAA
--	---

Tỉ lệ tính theo công thức độ chói tương đối của WCAG 2.1. Nguyên nhân: Tailwind v4 đặt lớp tiện ích vào @layer utilities, mà một quy tắc không thuộc tầng nào luôn thắng mọi quy tắc có tầng, bất kể độ đặc hiệu — nên text-text-invert trên thẻ <button> không có tác dụng.

Hình 4.3 (Nguồn: tác giả)

Về lỗi số 9: lỗi này do một vòng rà soát mã độc lập tìm ra **sau khi** tác giả đã tự kiểm thử và cho rằng chức năng đã hoàn chỉnh. Đây là lý do đề tài giữ bước rà soát độc lập ở cuối mỗi giai đoạn.

Về lỗi số 10 và số 11: cả hai lộ ra trong lúc **chụp ảnh màn hình cho báo cáo**, không phải trong lúc kiểm thử. Lỗi 10 tìm ra khi một kịch bản tự động thử mở chi tiết một đơn bất kỳ và không mở được; lỗi 11 tìm ra khi mở rộng phạm vi quét khả năng tiếp cận từ sáu lên mười màn hình quản trị. Bài học giống nhau: **một màn hình chưa ai thao tác tới là một màn hình chưa được kiểm.**

4.4. Kiểm thử phi chức năng

4.4.1. Khả năng tiếp cận

Quét tự động bằng axe-core trên **17 màn hình** — 7 công khai và 10 quản trị — ngay trên bản đóng gói đang chạy, đi qua đúng máy chủ web và đúng chính sách bảo mật nội dung của bản triển khai: **không còn lỗi vi phạm** hướng dẫn khả năng tiếp cận nội dung web phiên bản 2.0 và 2.1 ở mức A và AA [13], trên tổng 356 lần quy tắc đạt.

Đo vùng chạm ở 3 độ rộng màn hình: **không còn vùng chạm dưới 44×44 điểm ảnh.**

Hình 4.1 thể hiện kết quả quét.

Kết quả quét khả năng tiếp cận tự động

Công cụ axe-core 4.13.0 · bộ quy tắc WCAG 2.0 và 2.1 mức A và AA · trình duyệt Chromium, quét trên bản đóng gói docker compose · ngày quét 20/9/2026

Màn hình	Đường dẫn	Vi phạm	Quy tắc đạt	Cần xem tay
A — Màn hình công khai (7)				
Trang chủ	/	0	24	1
Danh sách loại phòng	/phong	0	17	0
Chi tiết loại phòng	/phong/phong-standard	0	21	1
Luồng đặt phòng	/dat-phong	0	19	1
Tra cứu đơn	/tra-cuu	0	20	0
Đăng nhập	/dang-nhap	0	26	0
Tin tức	/tin-tuc	0	16	0
B — Màn hình quản trị (10)				
Tổng quan	/admin	0	23	1
Đơn đặt phòng	/admin/bookings	0	23	1
Chi tiết đơn	/admin/bookings/40	0	23	1
Đối soát thanh toán	/admin/payments	0	21	1
Loại phòng	/admin/room-types	0	21	0
Phòng và ngày khả dụng	/admin/rooms	0	23	1
Khuyến mãi	/admin/promotions	0	17	0
Đánh giá	/admin/reviews	0	25	1
Nội dung trang chủ	/admin/content/sections	0	20	0
Tin tức (quản trị)	/admin/content/posts	0	17	0
Tổng 17 màn hình		0	356	9

Cột “Cần xem tay” là các mục axe-core không tự kết luận được (chủ yếu là độ tương phản nền ảnh); các mục này đã được kiểm tra thủ công bằng công thức tương phản WCAG.

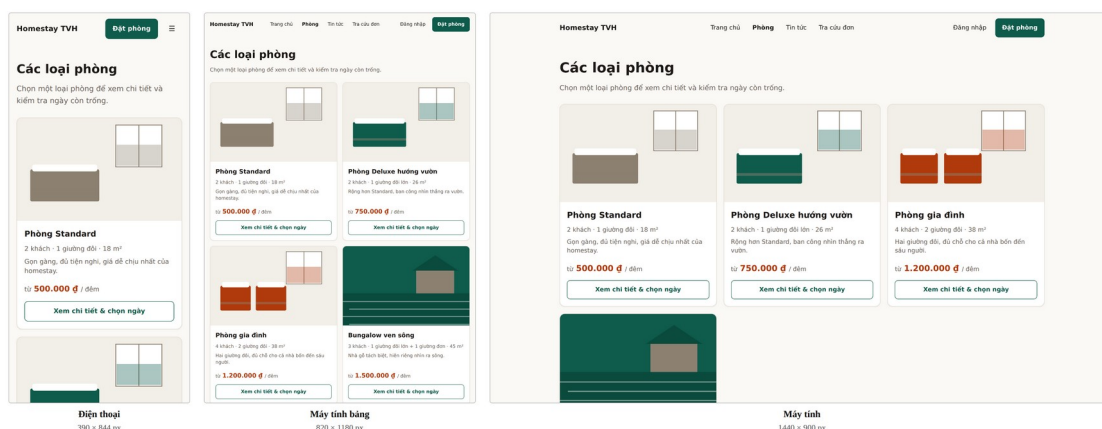
Hình 4.1 — Kết quả quét (Nguồn: tác giả)

4.4.2. Kiểm thử bảo mật

Chín kịch bản tấn công được thử trên hệ thống đang chạy, **tất cả đều bị chặn**: giả mạo tiêu đề địa chỉ để vượt giới hạn tần suất; gọi endpoint quản trị không token hoặc bằng token vai trò khách; dùng token cũ sau khi đổi mật khẩu; gọi webhook không khoá xác thực; gửi lại cùng một webhook; chen thẻ kịch bản vào nội dung quản lý; xem trạng thái thanh toán chỉ bằng mã đơn; và truy cập đơn của người khác qua tham số đường dẫn. Bảng chi tiết từng kịch bản và kết quả trình bày ở Phụ lục M.

4.4.3. Kiểm thử đáp ứng

Hình 4.2 thể hiện giao diện trên ba kích thước màn hình: điện thoại, máy tính bảng và máy tính để bàn.



Hình 4.2 — Giao diện trên ba kích thước màn hình: điện thoại, máy tính (Nguồn: tác giả)

4.4.4. Kiểm thử phía tầng giao diện

Tầng giao diện **không có bộ kiểm thử tự động thường trực**. Chất lượng được canh bằng ba công kiểm tra:

1. Biên dịch, kiểm kiểu và kiểm mẫu hiển thị của khung ứng dụng.
2. Script kiểm tra mã màu viết trực tiếp.
3. Công cụ kiểm tra quy ước mã nguồn.

Kiểm thử giao diện trong các giai đoạn trước thực hiện bằng trình duyệt thật và được ghi lại trong báo cáo từng giai đoạn, không phải một bộ kiểm thử thường trực. **Đây là một giới hạn đã biết**, trình bày ở mục 4.7.

4.5. Kiểm thử thủ công trước khi bảo vệ

Ngoài bộ kiểm thử tự động, đề tài xác định một danh sách **mười bước kiểm thử thủ công** cần chạy trên bản đóng gói trước khi trình diễn, phủ toàn bộ luồng nghiệp vụ chính: từ xem trang chủ, đặt đơn tới khi ra mã QR, tra cứu và huỷ đơn, đăng nhập quản trị và đổi mật khẩu bắt buộc, đối soát thanh toán, sửa nội dung trang chủ, xem thư xác nhận, tới đóng phòng theo khoảng ngày và kiểm chứng số phòng giảm đúng một. Danh sách đầy đủ trình bày ở Phụ lục N.

4.6. Đánh giá kết quả đạt được

4.6.1. Đối chiếu với mục đích ban đầu

#	Mục đích	Kết quả	Bảng chứng
1	Khách tìm và đặt phòng thành công	Đạt	Kiểm thử thủ công và 6 ca tự động

#	Mục đích	Kết quả	Bảng chứng
2	Không bao giờ bán trùng phòng	Đạt	3 ca kiểm thử đa luồng thật
3	Thanh toán mã QR và webhook tự xác nhận	Đạt	10 ca kiểm thử webhook
4	Không để tiền biến mất im lặng	Đạt	5 ca kiểm thử đưa thanh toán
5	Quản lý phòng, giá, số khách, ngày khả dụng	Đạt	9 ca kiểm thử khoảng đóng phòng
6	Giao diện đạt chuẩn thương mại	Đạt	Không còn lỗi vi phạm WCAG mức A và AA
7	Một lệnh là đủ để chạy toàn hệ thống	Đạt có điều kiện	Xem mục 4.6.3
8	Tài liệu kỹ thuật đầy đủ	Đạt	12 tài liệu

4.6.2. Đối chiếu với yêu cầu của đề tài

Yêu cầu	Đáp ứng
Hiển thị phòng, tiện nghi và hình ảnh	Đạt
Tìm phòng theo ngày	Đạt
Gửi yêu cầu đặt phòng	Đạt
Quản lý trạng thái đơn	Đạt — tám trạng thái, máy trạng thái có kiểm thử
Quản trị thông tin phòng	Đạt
Quản trị viên cập nhật phòng, giá, số lượng khách và ngày khả dụng	Đạt đủ bốn vế
Hệ thống kiểm tra trùng ngày	Đạt — thực hiện ở tầng cơ sở dữ liệu
Tính chi phí dự kiến	Đạt — một nơi tính tiền duy nhất
Không yêu cầu thanh toán thật	Đạt — có endpoint mô phỏng
Có dữ liệu minh hoạ để trình diễn	Đạt — 40 đơn đủ tám trạng thái

4.6.3. Những điều chưa kiểm chứng được

Đề tài nêu rõ giới hạn của chính quá trình kiểm thử:

- Toàn bộ bản đóng gói đã được dựng lên và kiểm chứng: bốn dịch vụ đều báo healthy (Hình 3.20), nginx phục vụ trang khách ở cổng 80, lời gọi `/api/room-types` đi xuyên qua nginx tới máy chủ ứng dụng trả về đủ bốn loại phòng, và thư xác nhận đi trọn đường hàng đợi thư → giao thức SMTP → hộp thư giả (Hình 3.21). Phần **chưa** kiểm chứng được chỉ còn là *tầng dựng ảnh*: môi trường phát triển có proxy chặn kho phụ thuộc Maven và npm từ bên trong container dựng ảnh, nên hai tệp `Dockerfile` được kiểm chứng ở tầng chạy với tệp `jar` và thư mục tĩnh dựng sẵn bên ngoài, chưa phải bằng một lệnh `docker compose up -d --build` chạy liền mạch. **Cần chạy lại đủ ba lệnh triển khai trên máy có kết nối mạng bình thường trước khi bảo vệ.**

- Tầng giao diện **không có bộ kiểm thử tự động thường trực**, như đã nêu ở mục 5.4.4. Hồi quy giao diện hiện phải phát hiện bằng mắt.

4.7. Các giới hạn đã biết của hệ thống

#	Giới hạn	Ảnh hưởng	Hướng khắc phục
1	Giới hạn tần suất lưu trong bộ nhớ tiến trình	Chỉ đúng khi chạy một bản ứng dụng	Chuyển sang bộ nhớ đệm dùng chung khi mở rộng
2	Webhook xác thực bằng khoá tĩnh, không phải chữ ký	Khoá lộ thì giả mạo được	Dùng chữ ký băm khi nhà cung cấp hỗ trợ
3	Không có token chống giả mạo yêu cầu liên trang	Rủi ro thấp vì token nằm trong tiêu đề, không phải cookie	Bổ sung nếu chuyển sang xác thực bằng cookie
4	Hoàn tiền là thao tác thủ công	Người quản trị phải tự chuyển khoản lại	Tích hợp giao diện hoàn tiền của nhà cung cấp
5	Không có nhật ký kiểm toán cho thao tác quản trị	Không truy được ai đã sửa gì	Bổ sung bảng nhật ký kiểm toán
6	Mật khẩu chỉ yêu cầu độ dài, không yêu cầu độ phức tạp	Người dùng đặt được mật khẩu yếu	Bổ sung kiểm tra độ mạnh
7	Không có giao thức bảo mật HTTPS trong bản đóng gói	Mật khẩu và token đi qua mạng dạng rõ	Bổ sung chứng chỉ khi có tên miền

Giới hạn số 7 là quan trọng nhất nếu đưa hệ thống ra sử dụng thật. Bản đóng gói phục vụ giao thức không mã hoá vì nó chạy trên máy cục bộ khi trình diễn.

CHƯƠNG 5. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

5.1. Kết luận

Đề tài đã xây dựng hoàn chỉnh một website giới thiệu và đặt phòng homestay gồm ba khối: trang bán hàng cho khách, khu quản trị cho chủ homestay, và giao diện lập trình ứng dụng với 80 thao tác trên 63 đường dẫn. Hệ thống chạy được bằng ba lệnh, kèm dữ liệu minh hoạ đủ để trình diễn mọi trạng thái nghiệp vụ.

Về mặt kỹ thuật, kết quả đáng kể nhất không phải số lượng chức năng mà là cách giải bài toán chống đặt trùng phòng: đặt ràng buộc ở tầng cơ sở dữ liệu bằng ràng buộc loại trừ trên kiểu khoảng, thay vì kiểm tra ở tầng ứng dụng. Lựa chọn này có căn cứ lý thuyết từ chính tài liệu PostgreSQL, vốn khuyến cáo không dựa vào việc kiểm tra ở tầng ứng dụng trước khi ghi ngay cả ở mức cô lập cao nhất [9]. Lời giải được chứng minh bằng kiểm thử đa luồng thật trên PostgreSQL thật, không phải bằng lập luận.

Cùng cơ chế đó được sử dụng lần thứ hai cho một bài toán khác — chống chồng lấn khoảng đóng phòng — cho thấy lựa chọn công nghệ không nhằm phục vụ một trường hợp duy nhất.

Về mặt quy trình, đề tài cho thấy giá trị của việc kiểm chứng bằng bằng chứng thay vì bằng khẳng định. Chín lỗi thật được ghi lại ở mục 4.3, trong đó có những lỗi mà việc biên dịch thành công hoàn toàn không phát hiện được.

Những nội dung đã tiếp thu được qua quá trình thực hiện:

- Mẫu kiểm tra rồi ghi ở tầng ứng dụng **không giải được** bài toán tranh chấp. Đây là hiểu biết mang tính nguyên lý, áp dụng lại được cho mọi bài toán đặt chỗ theo khoảng.
- Hành vi huỷ giao dịch của hệ quản trị cơ sở dữ liệu quan hệ ảnh hưởng trực tiếp lên thiết kế mã ứng dụng, không phải chi tiết có thể bỏ qua.
- Kiểm thử phải chạy trên hạ tầng thật khi đối tượng cần kiểm thử chính là hành vi của hạ tầng đó.
- Việc biên dịch thành công không nói gì về việc giao diện có hiển thị đúng hay không.

5.2. Hướng phát triển

5.2.1. Ngắn hạn — cần thực hiện trước khi đưa vào sử dụng thật

1. Bổ sung giao thức bảo mật HTTPS bằng chứng chỉ miễn phí.
2. Bổ sung nhật ký kiểm toán cho thao tác quản trị.
3. Kết nối tài khoản dịch vụ thanh toán thật.
4. Thay dữ liệu mẫu bằng dữ liệu thật của cơ sở lưu trú.

5.2.2. Trung hạn

1. Chuyển giới hạn tần suất sang bộ nhớ đệm dùng chung để chạy được nhiều bản ứng dụng song song.
2. Xây dựng bộ kiểm thử giao diện tự động để chống hồi quy.
3. Bổ sung bảng giá theo mùa. Hiện giá cố định theo loại phòng, chưa có giá cuối tuần hay giá ngày lễ.
4. Đồng bộ lịch hai chiều với các sàn đặt phòng qua chuẩn lịch mở, để cơ sở vừa bán trên sàn vừa bán trên website riêng mà không đặt trùng.

5.2.3. Dài hạn

1. Xây dựng ứng dụng di động sử dụng lại nguyên giao diện lập trình ứng dụng hiện có.
2. Mở rộng thành nền tảng phục vụ nhiều chi nhánh.
3. Gợi ý phòng dựa trên lịch sử đặt của khách.